

Solicitante: I.T.S - Instituto Tecnológico Superior Arias Balparda.

Nombre Fantasía, de la nueva empresa: Lidenskap

Grupo: 3ºMK

Turno: Matutino

Unidad Curricular: Tecnologías de la información

Nombres de los integrantes del grupo: Sofía Prieto, Federico Rodríguez, Gastón Visos, Joaquín Villena.

Fecha de entrega:28/10/2026

Instituto Tecnológico Superior Arias Balparda.
Blvr. José Batlle y Ordóñez 3570 esq. Gral. Flores – Montevideo.

BLOQUE A: Documento de calidad de software en entornos web (familia ISO 25000) 4
1. La familia ISO/IEC 25000 (SQuaRE)..... 4
2. Modelo de calidad aplicado (ISO/IEC 25010:2023)..... 5
3. Proceso de evaluación (ISO/IEC 25040)..... 5
4. Métricas y resultados (ISO/IEC 25023)..... 7
5. Resultado por característica..... 10
Métricas M01–M21..... 10
BLOQUE B: Encuesta de percepción de calidad..... 11
1. Objetivo..... 11
2. Público..... 11
4. Resultados..... 13
Conclusiones:..... 14
BLOQUE C: Plan de seguridad web basado en OWASP..... 15
1. Arquitectura del sistema..... 15
2. Metodología..... 16
3. Análisis por riesgo OWASP Top 10..... 16
A01: Pérdida de control de acceso..... 16
A02: Configuración de seguridad incorrecta..... 17
A03: Fallas en la cadena de suministro de software..... 18
A04: Fallas criptográficas..... 18
A05: Inyección (SQL, XSS y CSV)..... 19
A06: Diseño inseguro..... 20
A07: Fallas de autenticación..... 21
A08: Fallas de integridad de software y datos..... 21
A09: Fallas de registro y monitoreo..... 22
4. Matriz resumen de riesgos..... 23
5. Pruebas de seguridad y monitoreo continuo..... 28
BLOQUE D - Cálculo de métricas de proyecto (punto de función)..... 30
1. Funciones de datos (ILF y EIF)..... 30
2. Funciones transaccionales (EI, EO y EQ)..... 31
2.1 Entradas externas (EI)..... 31
3. Salidas externas (EO)..... 33
3.1 Consultas externas (EQ)..... 35
4. Puntos de función sin ajustar (PFSA)..... 36
5. Factor de ajuste y puntos de función ajustados (PFA)..... 36
6. Conclusiones..... 38
BLOQUE E: Manual de usuario operacional..... 38
1. Quién puede hacer qué..... 39

2. Conceptos básicos..... 39
3. Moverse por el sitio..... 39
4. Tocá Crear cuenta. Entrás automáticamente a tu perfil como Usuario público.....40
5. Consultar torneos, calendario y posiciones.....41
6. Ver el calendario.....42
7. Mi perfil (Administrador)..... 43
8. Gestionar un torneo (Organizador y Administrador)..... 44
8. Crear competencia.....45
9. Generar enfrentamientos (rondas y llaves).....46
10. Cargar y corregir resultados.....47
11. Consultar posiciones y reportes..... 47
12. Publicar información.....47
13. Cargar resultados como Árbitro..... 47
BLOQUE F: Manual de administrador.....48
1. Accesos del administrador..... 48
2. Panel general..... 49
3. Usuarios y roles.....50
BLOQUE G: Diagrama de Gantt (cronograma de la gestión del proyecto completo).....52

BLOQUE A: Documento de calidad de software en entornos web (familia ISO 25000)

Evaluamos la pagina con el modelo ISO/IEC 25010:2023 y el proceso ISO/IEC 25040. El resultado global es 62 %. Solo la compatibilidad supera el limite de 80 %; capacidad de interacción, eficiencia, fiabilidad y flexibilidad quedan en 75 %, y la adecuación funcional (50 %), la seguridad (43 %) y la mantenibilidad (33 %) quedan por debajo del 60 %l.

1. La familia ISO/IEC 25000 (SQuaRE)

La familia ISO/IEC 25000, conocida como SQuaRE (Systems and software Quality Requirements and Evaluation), reúne las normas para especificar y evaluar la calidad del software. Se organiza en cinco divisiones:

División	Normas	Qué define	Uso
Gestión de la calidad	ISO/IEC 2500n	Términos, guía general y gestión de la evaluación	Vocabulario común
Modelo de calidad	ISO/IEC 2501n	Características y subcaracterísticas de calidad (25010 producto, 25019 calidad en uso, 25012 datos)	modelo aplicado al SGDM
Medición de la calidad	ISO/IEC 2502n	Métricas y fórmulas para medir cada característica (25023 producto, 25022 en uso)	métricas
Requisitos de calidad	ISO/IEC 2503n	Cómo expresar requisitos de calidad (25030)	Vínculo con los RNF de la segunda entrega
Evaluación de la calidad	ISO/IEC 2504n	Proceso para evaluar un producto (25040, 25041)	proceso seguido

2. Modelo de calidad aplicado (ISO/IEC 25010:2023)

Característica	Subcaracterísticas	Qué significa en el SGDM	Prioridad
Adecuación funcional	Completitud, corrección, pertinencia	Que estén los 9 módulos mínimos y los RF-08 a RF-20, y que calculen bien tablas, llaves y emparejamientos	Alta (peso 3)
Seguridad	Confidencialidad, integridad, no repudio, responsabilidad, autenticidad, resistencia	La letra exige tratar los datos como "muy delicados" y registrar todo cambio en la base de datos (RNF-07)	Alta (peso 3)
Capacidad de interacción	Reconocibilidad, aprendizaje, operabilidad, protección contra errores, compromiso, inclusividad, asistencia, autodescripción	Usuarios sin conocimientos técnicos; mensajes de error que orienten; 78 % accede desde el celular (RNF-03, RNF-05)	Alta (peso 3)
Fiabilidad	Ausencia de fallos, tolerancia a fallos, disponibilidad, recuperabilidad	Recuperarse de una caída sin perder datos (RNF-09) y respaldos diarios	Media (peso 2)
Mantenibilidad	Modularidad, reusabilidad, analizabilidad, modificabilidad, testabilidad	Arquitectura MVC con capas separadas (RNF-10)	Media (peso 2)
Eficiencia de desempeño	Comportamiento temporal, uso de recursos, capacidad	La VM del instituto tiene 1 vCPU y 4 GB de RAM (RNF-08)	Media (peso 2)
Flexibilidad	Adaptabilidad, escalabilidad, instalabilidad, reemplazabilidad	Despliegue con Docker y diseño responsive desde 360 px	Media (peso 2)
Compatibilidad	Coexistencia, interoperabilidad	API en JSON y convivencia con Netdata y los scripts en la misma VM	Baja (peso 1)
Protección (Safety)	Restricción operativa, identificación de riesgos, falla segura	No aplica: el SGDM no controla equipos físicos ni puede causar daño a personas	No aplica

3. Proceso de evaluación (ISO/IEC 25040)

Seguimos las cinco actividades del proceso de evaluación de la norma:

1. Establecer los requisitos de la evaluación.
    - Propósito: medir el estado del producto a tres semanas de la entrega final y obtener un plan de mejora.
    - Objeto evaluado: el contenido de la carpeta SGDM App/ del repositorio.

2. Especificar la evaluación. Se eligieron 21 métricas basadas en ISO/IEC 25023, cada una con fórmula, umbral y criterio de decisión: Cumple = 1, Parcial = 0,5, No cumple = 0.

3. Diseñar la evaluación.

    - Entorno: réplica local con PHP 8.3 y MariaDB 10.11, con el esquema 01-schema.sql, los usuarios de 02-users.sh, las 5 cuentas de demostración, 60 torneos y 60 inscripciones de prueba.
    - Herramientas: 25 pruebas HTTP con curl sobre la API, navegador Chromium automatizado (Playwright) para la interfaz y revisión del código fuente.

4. Ejecutar la evaluación. Se midieron los tiempos de respuesta con 60 y con 5.000 torneos, y se revisó el ancho de cada página a 360 px.

5. Concluir la evaluación. Se calculó el cumplimiento por característica y el puntaje global ponderado y se armó el plan de mejora.

4. Métricas y resultados (ISO/IEC 25023)

ID	Característica / subcaracterística	Métrica y fórmula	Umbral	Valor medido	Resultado
M01	Adecuación funcional / completitud	RF implementados ÷ RF especificados (RF-08 a RF-20; parcial = 0,5)	≥ 0,90	4 ÷ 13 = 0,31 (completos: RF-14, RF-20; parciales: RF-11, RF-15, RF-18, RF-19)	No cumple
M02	Adecuación funcional / corrección	Pruebas funcionales y de permisos que pasan ÷ ejecutadas	1,00	19 ÷ 19 = 1,00	Cumple
M03	Eficiencia / comportamiento temporal	Tiempo medio de api/torneos.php con 60 torneos (5 mediciones)	≤ 500 ms	2,6 ms	Cumple
M04	Eficiencia / capacidad	Tamaño de la respuesta del listado con 5.000 torneos	≤ 200 KB	1,83 MB en 45–64 ms (sin paginación)	Parcial
M05	Compatibilidad / interoperabilidad	Endpoints que responden JSON con código HTTP estándar ÷ total	1,00	7 ÷ 7 = 1,00	Cumple
M06	Interacción / protección contra errores	Entradas inválidas rechazadas con mensaje que explica la causa ÷ probadas	≥ 0,90	6 ÷ 7 = 0,86 (cupo menor a 2 devuelve "Completá todos los campos")	Parcial
M07	Interacción / inclusividad	Imágenes con alt y controles con etiqueta ÷ total (9 páginas)	1,00	45 ÷ 45 imágenes y 67 ÷ 67 controles	Cumple
M08	Fiabilidad / recuperabilidad	Pérdida máxima de datos (RPO)	≤ 24 h	24 h (respaldo diario 03:00, 7	Cumple

ID	Característica / subcaracterística	Métrica y fórmula	Umbral	Valor medido	Resultado
		según `respaldo_sgdm.sh`		copias; copia externa en Drive	
M09	Fiabilidad / disponibilidad	Servicios que se levantan solos tras reiniciar la VM ÷ servicios	1,00	0 ÷ 2 (sin `restart:` en `docker-compose.yml`)	Parcial
M10	Seguridad / confidencialidad	Contraseñas almacenadas con hash bcrypt ÷ total	1,00	1,00 (`password_hash`)	Cumple
M11	Seguridad / integridad (inyección SQL)	Consultas con datos del usuario hechas con sentencias preparadas ÷ total	1,00	1,00; prueba `' OR '1'='1` rechazada	Cumple
M12	Seguridad / integridad (XSS)	Textos ingresados por usuarios que se muestran escapados ÷ total	1,00	0: un nombre `<img src=x onerror=alert(1)>` cargado en el registro se ejecuta al abrir *Usuarios y roles*	No cumple
M13	Seguridad / autenticidad	Endpoints de escritura que verifican sesión y rol en el servidor ÷ total	1,00	5 ÷ 5 (401 sin sesión, 403 con rol incorrecto)	Cumple
M14	Seguridad / responsabilidad	Acciones de escritura que quedan en `auditoria_registro` ÷ acciones	1,00	0 ÷ 5 (la tabla existe pero nada escribe en ella)	No cumple
M15	Seguridad / resistencia	Bloqueo tras intentos fallidos	≤ 5 intentos	Sin bloqueo tras 10 intentos	No cumple

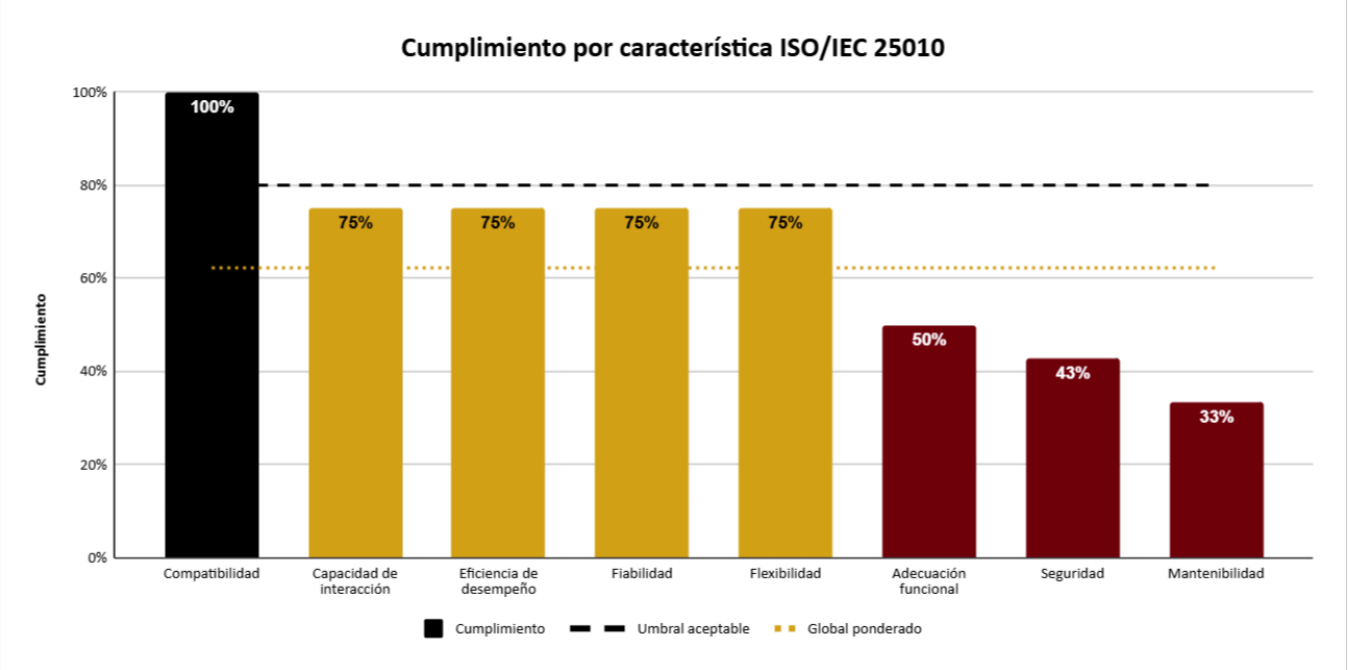
ID	Característica / subcaracterística	Métrica y fórmula	Umbral	Valor medido	Resultado
		de inicio de sesión			
M16	Seguridad / resistencia	Cookie de sesión con HttpOnly, Secure y SameSite + cabeceras CSP, X-Frame-Options, X-Content-Type-Options	6 ÷ 6	0 ÷ 6	No cumple
M17	Mantenibilidad / modularidad	Líneas del archivo más grande	≤ 500	main.js: 1.973 líneas (toda la interfaz y los datos de muestra)	No cumple
M18	Mantenibilidad / reusabilidad	Modelos que heredan del CRUD base Model.php ÷ modelos	≥ 0,90	16 ÷ 16 = 1,00	Cumple
M19	Mantenibilidad / testabilidad	Pruebas automatizadas incluidas en el repositorio	≥ 1 suite	0	No cumple
M20	Flexibilidad / adaptabilidad	Páginas públicas sin desplazamiento horizontal a 360 px ÷ total	1,00	6 ÷ 8 = 0,75 (privacidad: 378 px; términos: 430 px)	Parcial
M21	Flexibilidad / instalabilidad	Comandos para instalar desde cero	≤ 5	3 (git clone, copiar .env, docker compose up -d)	Cumple

5. Resultado por característica

El cumplimiento de cada característica es el promedio de sus métricas;

- El global pondera por prioridad (Alta 3, Media 2, Baja 1): (3 × 0,50 + 3 × 0,43 + 3 × 0,75 + 2 × 0,75 + 2 × 0,33 + 2 × 0,75 + 2 × 0,75 + 1 × 1,00) ÷ 18 = 0,62.
- Escala de decisión: 80 % o más, aceptable; 60 a 79 %, aceptable con condiciones; menos de 60 %, no aceptable.

Métricas M01–M21



BLOQUE B: Encuesta de percepción de calidad

1. Objetivo

Conocer la calidad percibida de la app por cada perfil de usuario después de usarlo en tareas reales, e identificar las diferencias entre lo que mide el equipo y lo que percibe el usuario.

2. Público

Qué queremos saber. Medir la satisfacción con el SGDM y la calidad percibida en cinco aspectos: facilidad de uso, rapidez, ausencia de errores, información correcta y confianza en la seguridad.

A quién va dirigida:

A las personas que usaron la app unos 10 minutos con la cuenta de demostración de su perfil

- Gestión (Administrador u Organizador) - Docentes que organizan competencias y referentes de clubes
- Competidor (Participante o Árbitro) - Estudiantes que juegan o arbitran torneos
- Público (sin cuenta) - Compañeros, familiares y espectadores

3. Cuestionario

1) ¿Con qué tipo de cuenta usaste el SGDM? (mide perfil)

Administrador u Organizador / Participante o Árbitro / Usuario público

2) ¿Desde qué dispositivo lo usaste? (mide perfil)

Celular / Computadora / Tablet

3) ¿Qué tan fácil te resultó encontrar lo que buscabas? (mide la capacidad de interacción)

Muy fácil / Fácil / Regular / Difícil / Muy difícil

4) ¿Pudiste hacer lo que querías sin ayuda? (mide la eficacia)

Sí, sin ayuda / Sí, con un poco de ayuda / No pude

5) ¿Cómo se ve y se usa el SGDM en tu dispositivo?

Muy bien / Bien / Regular / Mal

6) ¿Qué tan rápido cargan las páginas? (mide la eficacia)

Muy rápido / Rápido / Normal / Lento / Muy lento

7) ¿Encontraste errores o cosas que no funcionaban? (mide la fiabilidad)

Ninguno / Uno o dos / Varios

Fiabilidad

8) ¿Los torneos, resultados y posiciones se mostraban claros y correctos? (mide la adecuación funcional)

Sí, todos / La mayoría / Pocos / Ninguno

9) ¿Qué tan seguro te sentís dejando tus datos en el SGDM? (mide la seguridad)

Muy seguro / Seguro / Poco seguro / Nada seguro

10) En general, ¿qué tan satisfecho quedaste con el SGDM? (mide la satisfacción)

Muy satisfecho / Satisfecho / Neutral / Insatisfecho / Muy insatisfecho

4. Resultados

1) ¿Con qué tipo de cuenta usaste el SGDM?

[x]Participante o Árbitro: (52 %)
[ ] Administrador u Organizador: (24 %)
[ ] Usuario público: (24 %)

2) ¿Desde qué dispositivo lo usaste?

[ ] Celular: (20 %)
[x] Computadora: (72 %)
[ ] Tablet: (8 %)

3) ¿Qué tan fácil te resultó encontrar lo que buscabas?

[ ] Muy fácil: 9 (36 %)
[x] Fácil: 11 (44 %)
[ ] Regular: 4 (16 %)
[ ] Difícil: 1 (4 %)
[ ] Muy difícil: 0 (0 %)

4) ¿Pudiste hacer lo que querías sin ayuda?

[x] Sí, sin ayuda: 17 (68 %)
[ ] Sí, con un poco de ayuda: 7 (28 %)
[ ] No pude: 1 (4 %)

5) ¿Cómo se ve y se usa la app en tu dispositivo?

[ ] Muy bien: 10 (40 %)
[x] Bien: 11 (44 %)
[ ] Regular: 3 (12 %)
[ ] Mal: 1 (4 %)

6) ¿Qué tan rápido cargan las páginas?

[x] Muy rápido: 12 (48 %)
[ ] Rápido: 9 (36 %)
[ ] Normal: 4 (16 %)
[ ] Lento: 0 (0 %)
[ ] Muy lento: 0 (0 %)

7) ¿Encontraste errores o cosas que no funcionaban?

[x] Ninguno: 15 (60 %)
[ ] Uno o dos: 8 (32 %)
[ ] Varios: 2 (8 %)

8) ¿Los torneos, resultados y posiciones se mostraban claros y correctos?

[ ] Sí, todos: 7 (28 %)
[x] La mayoría: 9 (36 %)
[ ] Pocos: 7 (28 %)
[ ] Ninguno: 2 (8 %)

9) ¿Qué tan seguro te sentís dejando tus datos?

[ ] Muy seguro: 5 (20 %)
[x] Seguro: 10 (40 %)
[ ] Poco seguro: 8 (32 %)
[ ] Nada seguro: 2 (8 %)

10) En general, ¿qué tan satisfecho quedaste con el SGDM?
[ ] Muy satisfecho: 7 (28 %)
[x] Satisfecho: 12 (48 %)
[ ] Neutral: 5 (20 %)
[ ] Insatisfecho: 1 (4 %)
[ ] Muy insatisfecho: 0 (0 %)

Conclusiones:

Cuatro de los ocho aspectos superan el 70 % favorable y cuatro quedan por debajo. Los que fallan coinciden con las características más débiles de la medición técnica (seguridad 43 % y adecuación funcional 50 %): lo que medimos y lo que percibe el usuario apuntan a lo mismo.

BLOQUE C: Plan de seguridad web basado en OWASP

Este plan define cómo nuestro proyecto cubre los diez riesgos del OWASP Top 10 (2021) y qué falta para llevarlo a producción. Partimos del código actual del repositorio, no de un sistema ideal: cada riesgo indica la medida ya implementada, el archivo donde está y la brecha a cerrar.

Objetivo. Proteger la confidencialidad de los datos personales de usuarios y atletas, la integridad de torneos, inscripciones y resultados, y la disponibilidad del sitio durante las competencias.

Alcance. Frontend (HTML, CSS y assets/js/main.js), backend PHP (app/api/*.php y app/src/), base MariaDB (db/) y sus dos despliegues: el entorno de desarrollo (SGDM App/Dockerfile y docker-compose.yml) y el servidor del ITS (Apache nativo en AlmaLinux 8 más una copia en Docker en el puerto 8080, /opt/sgdm/docker). El endurecimiento del sistema operativo (firewall, SSH, antivirus) se documenta en Administración de Sistemas Operativos (SEGURIDAD.md) y la criptografía en Ciberseguridad (CRIPTOGRAFIA.md); acá solo se citan cuando protegen a la aplicación web.

Activos a proteger.

- Cuentas y credenciales: tabla usuario, contraseñas con hash bcrypt y la cookie de sesión PHPSESSID.
- Datos personales: nombre, apellido y correo de usuarios y participantes.
- Datos de competencia: torneos, inscripciones, enfrentamientos, resultados y tabla de posiciones.
- Registro de auditoría (auditoria_registro), que prueba quién hizo cada cambio.
- Credenciales de la base en .env y claves de respaldo en /etc/sgdm/respaldos/.

1. Arquitectura del sistema

SGDM es una aplicación de tres capas: un frontend HTML y JavaScript, una API REST en PHP 8.3 sobre Apache y una base MariaDB 11.4. El frontend nunca habla con la base; toda escritura pasa por la API, que valida la sesión de servidor y el rol.

La sesión real vive en una cookie de PHP (Auth.php); lo que el frontend guarda en sessionStorage solo decide qué botones mostrar. Hay dos roles de cuenta, Administrador y Usuario público, y tres roles por torneo, Organizador, Árbitro y Participante, que la API consulta en vivo en vista_rol_torneo.

2. Metodología

El análisis sigue el OWASP Top 10 2021, la lista de referencia de riesgos en aplicaciones web, y usa el OWASP ASVS 4.0 nivel 1 como lista de verificación de los controles mínimos.

Prioridad	Criterio	Plazo de corrección
Alta	Explotable sin credenciales o compromete cuentas de administrador	Antes de publicar el sistema
Media	Requiere sesión o condiciones previas, o afecta solo a un usuario	Durante la siguiente iteración
Baja	Mejora de defensa en profundidad	Mantenimiento planificado

3. Análisis por riesgo OWASP Top 10

A01: Pérdida de control de acceso

Estado: parcial.

- Existente. Auth::requireLogin(), requireRole() y requireTorneoRole() (app/src/Auth.php) cortan con 401 o 403 antes de cualquier escritura. Hay dos roles de cuenta, Administrador y Usuario público; Organizador, Árbitro y Participante son roles por torneo que se leen en cada petición de vista_rol_torneo (RolesTorneo::tiene()) y se apagan solos cuando el torneo finaliza.
- Existente. Reglas de negocio en el servidor: solo el árbitro asignado carga el resultado de su partido (api/resultados.php); validar y registrar walkover es del Organizador; reabrir una ronda, borrar torneos y gestionar usuarios es solo del Administrador. Un Usuario público que crea un torneo deja una solicitud en estado solicitado, oculta al público hasta que el Administrador la apruebe.
- Existente. El autorregistro siempre crea un Usuario público y el panel solo asigna Administrador o Usuario público como rol de cuenta (lista blanca en api/usuario.php). Un Administrador no puede desactivarse ni quitarse el rol a sí mismo, las bajas son lógicas (estado = 'inactivo') y una invitación solo la puede aceptar la persona invitada.

- Existente (frontend). hasPermission() en main.js oculta opciones según el rol guardado en sessionStorage. Es solo estético: la decisión real la toma el servidor, que es lo correcto.
- SSRF (incluido en A01 desde 2025). No aplica hoy: el backend no hace peticiones salientes (solo lee php://input). Si se agregan logos desde una URL, se validarán con lista blanca de dominios y bloqueo de IP internas.
- Brecha. El rol de cuenta y el estado se toman de $_SESSION (Auth::current()): un usuario desactivado, o un Administrador pasado a Usuario público, conserva sus permisos hasta que su sesión vence.
- Brecha. No hay token anti-CSRF y ocho endpoints aceptan $_POST si el cuerpo no es JSON (login, register, usuarios, torneos, resultados, solicitudes, equipos, rondas). Hoy lo mitiga la cookie SameSite=Lax, que el navegador no envía en un POST desde otro sitio; quedan expuestos navegadores sin SameSite y otra aplicación servida en el mismo dominio o IP.
- Brecha. app/src/ está dentro de la raíz web: /src/Auth.php responde 200 (vacío, no muestra código; verificado).
- Brecha. La columna participante.perfil_publico no se usa: los nombres de todos los inscriptos se publican en api/torneo.php aunque el participante lo haya desactivado.
- Medidas. M-01 revalidar estado y rol contra la base; M-02 aceptar solo application/json y verificar Origin; M-03 bloquear src/ y el listado de directorios; M-04 respetar perfil_publico.

A02: Configuración de seguridad incorrecta

Estado: parcial.

- Existente (servidor). La imagen de /opt/sgdm/docker usa php.ini-production, expose_php = Off, ServerTokens Prod y ServerSignature Off; MariaDB no publica puertos y vive en una red interna; el contenedor web solo recibe las credenciales de sgdm_app; docker_sgdm.sh genera contraseñas aleatorias con openssl rand -hex 16. En el Apache nativo, firewalld solo abre 22, 80 y 443.
- Existente. Mínimo privilegio en la base: sgdm_app solo tiene SELECT, INSERT, UPDATE y DELETE, sin DDL, y sgdm_consulta es de solo lectura (db/02-users.sh).
- Existente. app/.htaccess envía Content-Security-Policy (script-src 'self', frame-ancestors 'none'), X-Content-Type-Options: nosniff, X-Frame-Options: DENY y Referrer-Policy.

- Brecha (alta). docker_sgdm.sh copia 03-seed-demo.sql a la base del servidor, así que la copia en Docker arranca con admin@lidenskap.com / admin123, contraseña publicada en el README del repositorio. La app no permite cambiar contraseñas, así que solo se corrige por SQL.
- Brecha. El entorno de desarrollo (SGDM App/Dockerfile) no tiene php.ini de producción: muestra errores con ruta y traza (ver A10) y anuncia X-Powered-By: PHP/8.3 (verificado). Su docker-compose.yml publica el puerto 3306 y pasa el .env completo, con las claves de root y de sgdm_admin, al contenedor web.
- Brecha. Apache tiene el listado de directorios activo por defecto y .htaccess no lo desactiva: /src/ y /api/ muestran la lista de archivos.
- Brecha. Faltan HSTS y Permissions-Policy.
- Medidas. M-03 Options -Indexes; M-05 quitar las cuentas demo del servidor; M-06 igualar la imagen de desarrollo a la del servidor; M-07 HSTS y Permissions-Policy.

A03: Fallas en la cadena de suministro de software

Estado: cubierto mayormente.

- Existente. La pila tiene versiones con soporte (PHP 8.3, MariaDB 11.4 LTS). No hay Composer, npm ni librerías de terceros: todo el PHP y el JavaScript es propio. En el servidor nativo dnf-automatic instala cada día las actualizaciones de seguridad con la firma GPG de AlmaLinux.
- Brecha. Las imágenes Docker usan etiquetas móviles (php:8.3-apache, mariadb:11.4): dos construcciones pueden traer versiones distintas, y nadie las escanea.
- Medidas. M-08 fijar versión de parche o digest, revisar cada mes y escanear con Trivy o Docker Scout.

A04: Fallas criptográficas

Estado: parcial.

- Existente. Contraseñas con password_hash(..., PASSWORD_DEFAULT) (bcrypt, costo 10 en PHP 8.3) y password_verify(); nunca se guarda texto plano ni se devuelve el hash al cliente. .env no se versiona.
- Existente. La cookie de sesión sale con HttpOnly, SameSite=Lax y Secure cuando la conexión es HTTPS (Auth::ensureStarted(); verificado).
- Existente. ssl_sgdm.sh crea la CA propia "Lidenskap CA SGDM", activa mod_ssl y redirige http a https (ver CRIPTOGRAFIA.md).

- Brecha (alta). Según el README de Ciberseguridad, ssl_sgdm.sh todavía no se ejecutó en el servidor real, y ni el script ni SSL.md están en el repositorio. Mientras tanto la contraseña del login y la cookie viajan sin cifrar.
- Brecha. La copia en Docker se publica solo por HTTP en el 8080, y Secure depende de detectar HTTPS en cada petición.
- Medidas. M-09 instalar HTTPS en el servidor y versionar el script; M-10 forzar Secure en producción y poner el 8080 detrás de HTTPS.

A05: Inyección (SQL, XSS y CSV)

Estado: cubierto.

- Existente (SQL). Toda consulta con datos del usuario usa sentencias preparadas de PDO, y Database.php desactiva la emulación (ATTR_EMULATE_PREPARES => false). Disciplina y formato pasan por listas blancas (Catalogos.php) y los ids se fuerzan a entero.
- Existente (XSS). main.js pasa por escapeHtml() todo dato del servidor que inserta con innerHTML (torneos, sede, descripción, inscriptos, equipos, auditoría, correo del menú); la ficha del torneo usa textContent. Además, la CSP script-src 'self' impide ejecutar un <script> o un onerror= aunque llegaran al HTML, y ninguna página tiene scripts en línea.
- Riesgo latente. Model::findBy(), create() y update() concatenan nombres de tabla y columna; hoy siempre vienen del código ('email', 'nombre_rol'…), nunca del usuario. El carrusel de torneos del inicio (renderTorneoCard()) interpola sin escapar, pero hoy no recibe datos del servidor.
- Brecha (baja). La exportación a CSV (downloadCsv()) no neutraliza celdas que empiezan con =, +, - o @: un nombre de torneo o un correo como =1+1@x.com (válido para FILTER_VALIDATE_EMAIL) se ejecuta como fórmula al abrir el archivo en Excel.
- Medidas. M-11 neutralizar fórmulas en CSV; M-12 regla de desarrollo (todo dato del servidor por escapeHtml() o textContent, columnas solo desde el código) y escapar el carrusel antes de conectarlo.

A06: Diseño inseguro

Estado: parcial.

- Existente. Las reglas de negocio viven en el servidor: las fases del torneo solo avanzan en orden (api/torneo.php), una ronda cerrada no se modifica, nadie puede tener dos papeles en el mismo torneo (RolesTorneo::yaVinculado()), las bajas son lógicas para no perder historial y las operaciones de varios pasos van en transacción.
- Brecha. api/torneos.php no valida largo máximo de nombre y sede (150 caracteres en la base), formato de fechaInicio ni tope de cupoMaximo; un valor fuera de rango termina en una excepción de la base (A10). Una disciplina personalizada crea una fila nueva en modulo_competencia aunque el torneo sea solo una solicitud.
- Brecha. El cupo se controla en dos pasos (cupoLleno() y después el INSERT): dos aprobaciones simultáneas pueden pasar el cupo.
- Brecha. La "Configuración del sistema" del panel, incluida "Auditoría obligatoria", se guarda en localStorage del navegador y no cambia nada en el servidor: aparenta un control que no existe.
- Medidas. M-13 validación completa en el servidor; M-14 cupo con bloqueo de fila; M-15 quitar o implementar en el servidor la configuración del panel.

A07: Fallas de autenticación

Estado: parcial.

- Existente. session_regenerate_id(true) al iniciar sesión y session.use_strict_mode evitan la fijación de sesión. El login responde "Correo o contraseña incorrectos" sin decir cuál falló, bloquea cuentas que no están activas y exige 8 caracteres en registro y alta. La cookie es HttpOnly, así que un script no puede robar la sesión.
- Existente (servidor). fail2ban tiene el jail sgdm-login: 10 logins fallidos (respuesta 401 de api/login.php) en 10 minutos bloquean la IP (SEGURIDAD.md).
- Brecha. Ese límite es solo por IP y solo en el Apache nativo: la copia en Docker y el entorno de desarrollo no tienen ninguno, y no hay límite por cuenta.
- Brecha. El registro responde "Ya existe una cuenta con ese correo", y el login tarda menos cuando el correo no existe (solo llama a password_verify() si lo encuentra): las dos cosas permiten saber qué correos tienen cuenta.
- Brecha. La sesión no vence de forma garantizada: PHP borra sesiones viejas al azar (gc_maxlifetime 1440 s) y no comprueba su edad al leerlas.
- Brecha. La política de contraseña solo exige largo, no existe cambio ni recuperación de contraseña y los administradores no tienen segundo factor.
- Medidas. M-16 límite por cuenta en la app; M-17 expiración por inactividad; M-18 respuestas sin enumeración; M-19 cambio de contraseña, rechazo de contraseñas comunes y 2FA para administradores.

A08: Fallas de integridad de software y datos

Estado: cubierto mayormente.

- Existente. El frontend no carga scripts de terceros y la CSP limita los orígenes a 'self' y Google Fonts.
- Existente. respaldo_sgdm.sh cifra cada respaldo con AES-256, guarda su hash SHA-256 y lo firma con RSA 4096; descifrar verifica hash y firma antes de restaurar, y una copia va a Google Drive.
- Brecha. La hoja de estilos de Google Fonts cambia según el navegador, así que no admite verificación con SRI.
- Brecha. Según el README de Ciberseguridad, el respaldo_sgdm.sh nuevo todavía no está instalado en el servidor real y quedan respaldos viejos sin cifrar, también en Drive. No hay prueba periódica de restauración.
- Medidas. M-20 instalar el respaldo nuevo y probar una restauración por mes; M-21 servir las fuentes desde el propio sitio.

A09: Fallas de registro y monitoreo

Estado: parcial.

- Existente. Auditoria::registrar() (app/src/Auditoria.php) guarda usuario, acción, tabla, detalle, fecha e IP de cada acción que cambia datos: inicios de sesión (también los fallidos), altas, ediciones y bajas de usuarios, torneos, resultados, rondas y el motivo de cada reapertura. El panel muestra el registro con búsqueda y exportación (api/auditoria.php, solo Administrador).
- Brecha. Las denegaciones 401 y 403 (Auth::deny()) no quedan registradas, y no hay alertas: nadie se entera de una ráfaga de logins fallidos o del alta de un Administrador hasta que mira el panel.
- Brecha. sgdm_app tiene UPDATE y DELETE sobre auditoria_registro: la misma cuenta que escribe el registro lo puede borrar.
- Brecha. Los logins fallidos con correos inexistentes se registran sin límite, así que se puede llenar la tabla; el panel solo muestra los 1000 eventos más recientes y no muestra el campo detalle.
- Medidas. M-22 registrar 401 y 403 y alertar; M-23 auditoría de solo inserción para sgdm_app.

A10: Falsificación de peticiones del lado del servidor

Estado: parcial.

- Existente. Los endpoints devuelven JSON con códigos coherentes (400, 401, 403, 404, 405, 409) y las operaciones de varios pasos usan transacciones, que PDO revierte si el script termina sin commit().
- Brecha. No hay manejador global de excepciones. Si la base no responde o rechaza un dato (fecha inválida, nombre de 151 caracteres), la PDOException no se captura. En el entorno de desarrollo la respuesta es HTTP 200 con un "Fatal error" en HTML, la ruta /var/www/html/src/Database.php y la traza completa (verificado); en el servidor, php.ini-production lo convierte en un 500 vacío. En los dos casos el frontend espera JSON y no muestra ningún mensaje.
- Medidas. M-24 manejador global que registre el error y devuelva un 500 JSON genérico; M-06 y M-13 reducen los casos.

4. Matriz resumen de riesgos

Riesgo OWASP 2025	Estado	Probabilidad	Impacto	Prioridad	Medidas
A02 Configuración incorrecta	parcial	Alta	Alto	Alta	M-03, M-05, M-06, M-07
A04 Fallas criptográficas	parcial	Media	Alto	Alta	M-09, M-10
A01 Control de acceso	parcial	Media	Alto	Alta	M-01, M-02, M-03, M-04
A07 Autenticación	Parcial	Media	Alto	Media	M-16, M-17, M-18, M-19
A10 Condiciones excepcionales	Parcial	Media	Medio	Media	M-24
A06 Diseño inseguro	Parcial	Media	Medio	Media	M-13, M-14, M-15
A09 Registro y alertas	Parcial	Media	Medio	Media	M-22, M-23
A08 Integridad	cubierto mayormente	Baja	Medio	Baja	M-20, M-21
A03 Cadena de suministro	cubierto mayormente	Baja	Medio	Baja	M-08
A05 Inyección	Cubierto	Baja	Medio	Baja	M-11, M-12

6. Plan de acción

Id	Medida	Dónde se aplica	Responsable	Fase
M-05	No copiar 03-seed-demo.sql al servidor; si ya se cargó, cambiar o desactivar las cuentas demo	docker_sgdm.sh, base del servidor	Infraestructura	1
M-09	Ejecutar ssl_sgdm.sh instalar en el servidor real, importar la CA en las PC de la defensa y subir ssl_sgdm.sh y SSL.md al repositorio	Servidor, repositorio	Infraestructura	1
M-01	Revalidar estado y rol de la cuenta contra la base en cada petición protegida	src/Auth.php	Backend	1
M-03	Options -Indexes en .htaccess y Require all denied en src/.htaccess	app/.htaccess, app/src/.htaccess	Backend	1
M-06	Igualar la imagen de desarrollo a la del servidor: php.ini-production, expose_php = Off, ServerTokens Prod, sin publicar 3306 y solo las variables de sgdm_app en el contenedor web	SGDM App/Dockerfile, docker-compose.yml	Infraestructura	1
M-24	Manejador global de excepciones: registrar en error_log y devolver 500 con JSON genérico	src/autoload.php	Backend	1

M-02	Aceptar solo Content-Type: application/json (quitar el respaldo a $_POST) y rechazar con 403 un Origin ajeno	api/*.php, src/Auth.php	Backend	1
M-16	Límite por cuenta en la app: 5 fallos en 15 minutos devuelven 429, además de fail2ban	api/login.php, api/register.php	Backend	1
M-20	Instalar el respaldo_sgdm.sh nuevo, guardar cifrado.clave fuera del servidor, borrar respaldos sin cifrar y probar una restauración por mes	Servidor, Google Drive	Infraestructura	1
M-10	Forzar session.cookie_secure = 1 en producción y poner el 8080 detrás de un proxy con HTTPS (o no exponerlo)	src/Auth.php, servidor	Infraestructura	2
M-13	Validación en el servidor: largos según la base, fecha con DateTime::createFromFormat('Y-m-d'), cupo entre 2 y un tope, disciplina personalizada creada solo al aprobar	api/torneos.php y demás endpoints de escritura	Backend	2
M-17	Cerrar la sesión tras 30 minutos sin actividad, comprobado en Auth::current()	src/Auth.php	Backend	2
M-18	Mensaje neutro en el registro y password_verify() contra un hash ficticio cuando el correo no existe	api/register.php, api/login.php	Backend	2

M-22	Registrar las respuestas 401 y 403 y alertar ante ráfagas de logins fallidos o altas de Administrador	Auth::deny(), Auditoria.php, monitoreo_sgdm.sh	Backend	2
M-23	Dejar a sgdm_app solo SELECT e INSERT sobre auditoria_registro (permisos por tabla)	db/02-users.sh	Infraestructura	2
M-11	Prefijar ' a las celdas CSV que empiezan con =, +, - o @	main.js (downloadCsv)	Frontend	2
M-15	Quitar del panel la "Configuración del sistema" o guardarla y aplicarla en el servidor	panel.html, main.js	Frontend	2
M-07	Agregar HSTS y Permissions-Policy una vez activo HTTPS	app/.htaccess o virtual host	Infraestructura	2
M-19	Cambio de contraseña, rechazo de contraseñas comunes y 2FA (TOTP) para administradores	Nuevo api/password.php, api/login.php	Backend	3
M-14	Controlar el cupo dentro de la transacción con SELECT … FOR UPDATE	RolesTorneo::cupoLleno(), api/solicitudes.php	Backend	3
M-04	Respetar perfil_publico en las listas públicas de inscriptos	api/torneo.php, api/rondas.php	Backend	3

M-12	Escapar renderTorneoCard() antes de conectarlo a la API y mantener la regla escapeHtml()/textContent	main.js, revisión de código	Frontend	3
M-08	Fijar imágenes a versión de parche o digest, revisarlas cada mes y escanearlas con Trivy o Docker Scout	Dockerfile, docker-compose.yml	Infraestructura	3
M-21	Servir las fuentes desde assets/fonts/ y quitar Google Fonts de la CSP	HTML, styles.css, .htaccess	Frontend	3

5. Pruebas de seguridad y monitoreo continuo

Cada medida se da por cerrada solo cuando pasa su caso de prueba; estos casos se suman al plan de testing de la entrega (PHPUnit para el backend, Cypress para el flujo en el navegador).

Caso	Riesgo	Pasos	Resultado esperado	Hoy	Herramienta
CS-01	A05	Enviar ' OR '1'='1 como correo en el login	401 "Correo o contraseña incorrectos."	Pasa	Cypress, sqlmap
CS-02	A05	Crear un torneo llamado <img src=x onerror=alert(1)>, aprobarlo y abrir torneos.html, el detalle y el panel	El texto se ve literal y no aparece la alerta	Pasa	Cypress
CS-03	A01	POST api/torneos.php sin sesión y con sesión de Usuario público	401 sin sesión; con Usuario público, 200 con solicitud: true y el torneo no aparece en GET api/torneos.php	Pasa	PHPUnit, curl
CS-04	A01	DELETE api/usuario.php?id= con el propio id del Administrador	400 "No podés desactivar tu propia cuenta."	Pasa	PHPUnit
CS-05	A01	Con un Usuario público, POST api/resultados.php en un partido que no arbitra	403 "Solo el árbitro asignado…"	Pasa	PHPUnit
CS-06	A01	Desde otro origen, enviar un formulario HTML a api/usuarios.php con un Administrador logueado	No se crea la cuenta: 401 hoy (el navegador no manda la cookie Lax); 403 tras M-02 aunque llegue	Pasa	Navegador, Burp Suite

CS-07	A01	Desactivar un usuario con sesión abierta y repetir su última acción	401	Falla (M-01)	PHPUnit
CS-08	A07	6 logins fallidos seguidos con el mismo correo	El sexto devuelve 429	Falla (M-16); en el servidor nativo fail2ban bloquea la IP al décimo	Cypress, fail2ban-client status sgdm-login
CS-09	A07	Registrarse con una contraseña de 7 caracteres	400 "La contraseña debe tener al menos 8 caracteres."	Pasa	PHPUnit
CS-10	A04, A02	Pedir http:// y revisar las cabeceras de https://…/api/login.php	Redirección a https://; Set-Cookie con Secure; HttpOnly; SameSite=Lax; CSP, HSTS, X-Frame-Options y nosniff	Falla (M-09, M-07)	curl, OWASP ZAP
CS-11	A02, A01	GET /src/, /api/ y /src/Auth.php	403 o 404, sin listado de archivos	Falla (M-03)	curl
CS-12	A10	Con sesión, POST api/torneos.php con fechaInicio: "abc" o un nombre de 151 caracteres	400 con mensaje claro (M-13) o 500 JSON genérico, sin rutas ni trazas	Falla (M-24)	curl
CS-13	A02	Iniciar sesión en el servidor con admin@lidenskap.com / admin123	401	Falla en la copia Docker (M-05)	curl
CS-14	A09	Un login fallido y abrir Panel → Auditoría	Aparece "Inicio de sesión fallido" con fecha e IP	Pasa	Cypress

BLOQUE D - Cálculo de métricas de proyecto (punto de función)

1. Funciones de datos (ILF y EIF)

Identificamos 9 archivos lógicos internos (ILF), todos de complejidad baja y ningún archivo de interfaz externo (EIF). Los ILF se agrupan en las tablas que el usuario reconoce como una sola entidad; los RET son los subgrupos de datos y los DET los campos reconocibles.

Matriz de complejidad ILF/EIF: 1 RET con hasta 50 DET = Baja; 2 a 5 RET con 1 a 19 DET = Baja; 2 a 5 RET con 20 a 50 DET = Media.

	ILF	Tablas del esquema	RET	DET	Complejidad	PF
1	Usuario	usuario	1	8	Baja	7
2	Competidor (participantes y equipos)	competidor, participante, equipo, equipo_participante	3	12	Baja	7
3	Torneo	torneo, torneo_modulo	2	13	Baja	7
4	Disciplina	modulo_competencia	1	3	Baja	7
5	Formato de torneo y puntaje	tipo_torneo	1	6	Baja	7
6	Inscripción	inscripcion	1	5	Baja	7
7	Fixture (rondas, partidos y resultados)	ronda, enfrentamiento, resultado	3	14	Baja	7
8	Tabla de posiciones	tabla_posiciones	1	6	Baja	7
9	Auditoría	auditoria_registro	1	6	Baja	7
Total ILF						**63**

2. Funciones transaccionales (EI, EO y EQ)

Identificamos 21 entradas externas (86 PF), 6 salidas externas (36 PF) y 9 consultas externas (37 PF). FTR = archivos referenciados por la transacción; DET = campos, botones y mensajes que cruzan la frontera. La columna Estado indica si la función ya está programada en el repositorio o queda planificada en el ESRE.

2.1 Entradas externas (EI)

Matriz EI: 0-1 FTR con 1-15 DET = Baja; 2 FTR con 5-15 DET = Media; 3 o más FTR con 1-4 DET = Media; 3 o más FTR con 5-15 DET = Alta. Pesos: Baja 3, Media 4, Alta 6.

	Entrada externa	Requisito	FTR	DET	Complejidad	PF	Estado
1	Registro de usuario público	RF-14	1	6	Baja	3	Implementado (register.php)
2	Alta de usuario administrativo	RF-19	1	7	Baja	3	Implementado (usuarios.php POST)
3	Modificar usuario y asignar rol	RF-19	1	7	Baja	3	Implementado (usuario.php PUT)
4	Baja lógica de usuario	RF-19	1	3	Baja	3	Implementado (usuario.php DELETE)
5	Editar perfil propio	RF-14	2	6	Media	4	Parcial (hoy en localStorage)
6	Alta de torneo	RF-08	3	10	Alta	6	Implementado (torneos.php POST)
7	Modificar torneo	RF-08	3	10	Alta	6	Planificado

8	Eliminar torneo (borra en cascada)	RF-19	4	3	Media	4	Implementado (torneo.php DELETE)
9	Confirmar avance de fase del torneo	RF-08	3	4	Media	4	Planificado
10	Inscribir competidor en torneo	RF-15	3	5	Alta	6	Planificado
11	Validar o rechazar inscripción	RF-15	1	4	Baja	3	Planificado
12	Alta y edición de participante	RF-15	2	7	Media	4	Planificado
13	Alta y edición de equipo con integrantes	RF-15	2	7	Media	4	Planificado
14	Generar calendario de liga	RF-16	4	4	Media	4	Planificado
15	Generar llave de eliminación directa	RF-17	4	4	Media	4	Planificado
16	Generar ronda de sistema suizo	RF-10	4	4	Media	4	Planificado

17	Cargar o corregir resultado	RF-09, RF-11, RF-17	5	6	Alta	6	Planificado
18	Registrar walkover (WO)	RF-12	3	5	Alta	6	Planificado
19	Cerrar ronda	RF-13	2	3	Baja	3	Planificado
20	Reabrir ronda con registro en auditoría	RF-13	2	4	Baja	3	Planificado
21	Habilitar o deshabilitar disciplina	RF-19	1	3	Baja	3	Planificado
Total EI						**86**	

3. Salidas externas (EO)

Una EO entrega datos con cálculo o información derivada.

Matriz EO:

- 0-1 FTR con 6-19 DET = Baja;

- 2-3 FTR con 6-19 DET = Media;
- 4 o más FTR con 6-19 DET = Alta;
- 2-3 FTR con 1-5 DET = Baja;
- 4 o más FTR con 1-5 DET = Media.
- Pesos: Baja 4, Media 5, Alta 7.

	Salida externa	Requisito	Cálculo que la hace EO	FTR	DET	Complejidad	PF	Estado
1	Tabla de posiciones	RF-09, RF-18	Puntos, partidos jugados y orden por desempate	4	9	Alta	7	Planificado (vista SQL creada)
2	Llave de eliminación directa	RF-17, RF-18	Ganador y avance a la siguiente ronda	3	8	Media	5	Planificado
3	Reportes generales de torneos	RF-19	Totales y agregados por torneo	4	8	Alta	7	Planificado
4	Listado y búsqueda de torneos	RF-18	Conteo de inscriptos y filtros	4	14	Alta	7	Implementado (torneos.php GET)
5	Resumen del panel según el rol	RF-14	Contadores y actividad reciente	3	6	Media	5	Parcial (panel con datos de ejemplo)
6	Respaldo de la base de datos	RF-20	Genera archivo de backup	9	3	Media	5	Implementado (respaldo_sgdm.sh)

Total EO	36

3.1 Consultas externas (EQ)

Una EQ recupera datos sin cálculos ni cambios.

Matriz EQ:

- 0-1 FTR con 1-19 DET = Baja;
- 2-3 FTR con 6-19 DET = Media;
- 4 o más FTR con 6-19 DET = Alta.
- Pesos: Baja 3, Media 4, Alta 6.

	Consulta externa	Requisito	FTR	DET	Complejidad	PF	Estado
1	Iniciar sesión (verificar credenciales)	RF-14	1	7	Baja	3	Implementado (login.php)
2	Detalle de torneo con inscriptos	RF-18	6	14	Alta	6	Implementado (torneo.php GET)
3	Listado de usuarios	RF-19	1	6	Baja	3	Implementado (usuarios.php GET)
4	Calendario de partidos por mes y fecha	RF-18	3	8	Media	4	Parcial (pantalla con datos de ejemplo)
5	Resultados de un torneo	RF-18	3	7	Media	4	Planificado
6	Registro de auditoría	RF-13	2	6	Media	4	Planificado
7	Listado de participantes y equipos	RF-15	2	7	Media	4	Planificado

8	Perfil y "Mis torneos"	RF-14	4	8	Alta	6	Parcial
9	Lista de disciplinas	RF-18	1	3	Baja	3	Parcial (catálogo fijo en el front)
Total EQ						**37**	

4. Puntos de función sin ajustar (PFSA)

Tipo de función	Baja (cant. × peso)	Media (cant. × peso)	Alta (cant. × peso)	Cantidad	PF
Entradas externas (EI)	8 × 3 = 24	8 × 4 = 32	5 × 6 = 30	21	86
Salidas externas (EO)	0 × 4 = 0	3 × 5 = 15	3 × 7 = 21	6	36
Consultas externas (EQ)	3 × 3 = 9	4 × 4 = 16	2 × 6 = 12	9	37
Archivos lógicos internos (ILF)	9 × 7 = 63	0 × 10 = 0	0 × 15 = 0	9	63
Archivos de interfaz externos (EIF)	0 × 5 = 0	0 × 7 = 0	0 × 10 = 0	0	0
Total				**45**	**222**

5. Factor de ajuste y puntos de función ajustados (PFA)

Las 14 características generales del sistema suman un grado total de influencia (TDI) de 39, lo que da un factor de ajuste de 1,04 y 231 PF ajustados. Cada característica se califica de 0 (sin influencia) a 5 (influencia fuerte).

	Característica	Valor	Justificación en la página

	general		
1	Comunicación de datos	4	Aplicación web: el navegador se comunica con la API PHP por HTTP y JSON.
2	Procesamiento distribuido	2	Front en JavaScript, lógica en PHP y datos en MySQL, en contenedores separados.
3	Rendimiento	3	RNF-08 exige tiempos aceptables en consultas públicas con varios torneos activos.
4	Configuración muy utilizada	1	Servidor estándar con Docker, sin restricciones especiales de hardware.
5	Tasa de transacciones	2	Volumen moderado, con picos en días de partido y carga de resultados.
6	Entrada de datos en línea	5	Todas las altas, ediciones y cargas se hacen en línea desde la web.
7	Eficiencia para el usuario final	4	Diseño Mobile-First (RNF-03), filtros, búsqueda, modo oscuro y menús según el rol.
8	Actualización en línea	3	Los ILF se actualizan en línea; hay respaldo automático contra pérdida de datos.
9	Procesamiento complejo	4	Desempate en liga (RF-09), emparejamiento suizo (RF-10), llaves (RF-17) y matriz de permisos.
10	Reusabilidad	2	Clase base Model y modelos por tabla reutilizables dentro del proyecto.
11	Facilidad de instalación	3	docker-compose, scripts SQL de esquema y datos de prueba, y scripts de instalación (RF-20).
12	Facilidad de	3	Scripts de respaldo, monitoreo y gestión del

	operación		servicio.
13	Instalación en múltiples sitios	1	Una sola instalación por organización, accesible desde cualquier navegador.
14	Facilidad de cambio	2	Disciplinas y formatos parametrizados en la base; configuración desde el panel.
Total (TDI)		**39**	

6. Conclusiones

SGDM es un sistema de tamaño pequeño a mediano, con 231 PF ajustados, y hoy tiene programado cerca de un tercio de sus funciones transaccionales.

Estado en el repositorio	PF transaccionales	Porcentaje
Implementado	46	29 %
Parcial (pantalla con datos de ejemplo o localStorage)	22	14 %
Planificado en el ESRE	91	57 %
Total EI + EO + EQ	159	100 %

BLOQUE E: Manual de usuario operacional

Este manual explica como usar la aplicación para su uso diario : consultar torneos, crear una cuenta, iniciar sesión, crear competencias, inscribir participantes, generar enfrentamientos, cargar resultados, consultar posiciones y publicar información.

1. **Quién puede hacer qué**

ROL-04 Usuario público: Cualquier visitante, con o sin cuenta. Puede ver torneos, calendarios, resultados y posiciones publicados

ROL-03 Participante: Jugador o equipo inscripto por un organizador. Puede ver torneos, calendarios, resultados y posiciones publicados, más su perfil y sus torneos

ROL-05 Árbitro: Persona asignada a encuentros. Puede cargar y actualizar resultados de sus encuentros mientras la ronda esté abierta

ROL-02 Organizador de torneo: Responsable de torneos asignados. Puede Inscribir participantes, generar rondas, cargar y publicar resultados, ver reportes de sus torneos

ROL-01 Administrador general: Responsable del sistema. Puede todo lo anterior en todos los torneos, crear competencias y administrar el sistema.

2. **Conceptos básicos**

Disciplina: Deporte o juego: Fútbol, Básquetbol, Ajedrez, Tenis, Esports, Voleibol, Rugby o una personalizada

Liga: Todos contra todos. Puntaje: victoria 3, empate 1, derrota 0

Eliminación directa: Llaves; quien pierde queda afuera y el ganador avanza a la ronda siguiente

Sistema suizo: Se empareja a participantes con puntaje parecido sin repetir rivales. Puntaje: victoria 1, tablas ½, derrota 0

Estado del torneo: Inscripciones abiertas (planificado), En curso, Finalizado o Cancelado

Inscripción: Pendiente hasta que el organizador la valida como Confirmada (o Rechazada). Solo los confirmados entran al calendario y las llaves

Ronda: Conjunto de enfrentamientos de una fecha. Pasa por Borrador, Publicada y Cerrada

Resultado: Pendiente hasta que se confirma como Oficial; solo los oficiales cuentan en la tabla

3. **Moverse por el sitio**

La barra superior lleva a Inicio, Disciplinas, Buscar torneos, Calendario, Crear competencia, Panel y Perfil. Las opciones que tu rol no puede usar no aparecen. A la derecha están Iniciar sesión (o Mi Perfil si ya entraste) y el botón que cambia entre modo

claro y oscuro.

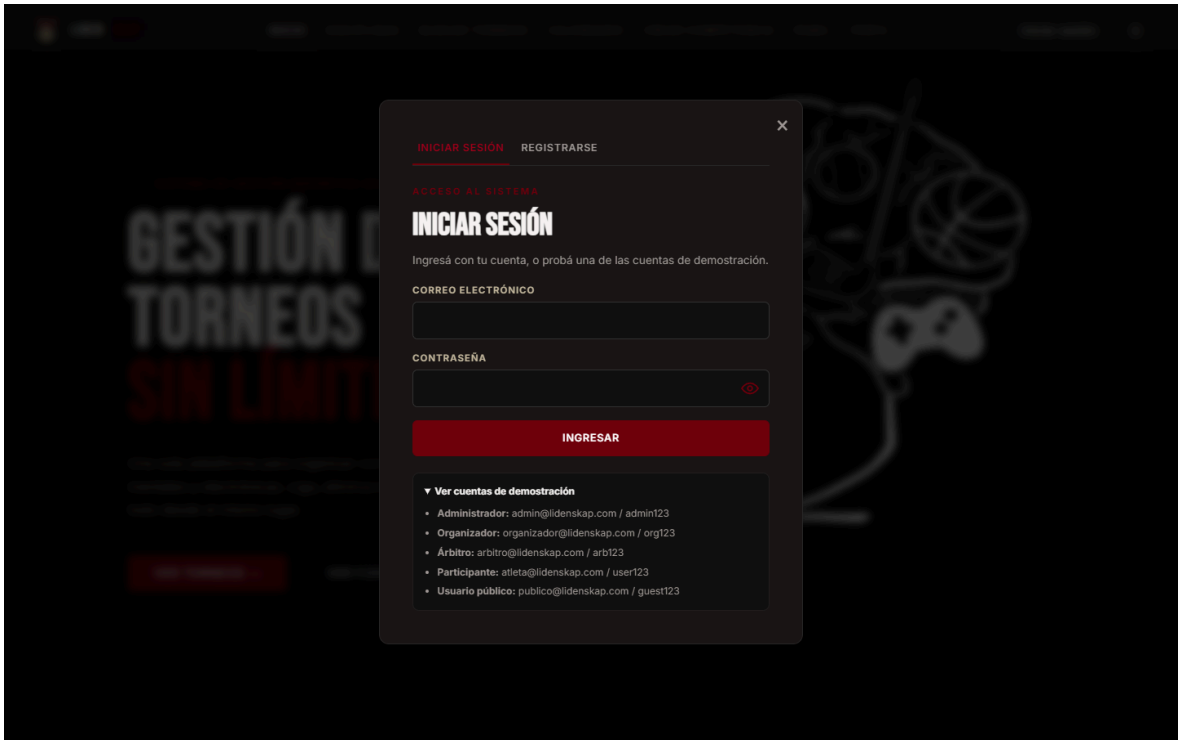


4. **Tocá Crear cuenta. Entrás automáticamente a tu perfil como Usuario público.**

Iniciar sesión

- Tocá Iniciar sesión en la barra superior.

- Formulario de acceso con las cinco cuentas de demostración (Administrador, Organizador, Árbitro, Participante y Usuario público) visibles al desplegar "Ver cuentas de demostración". El campo de contraseña tiene un botón para mostrar/ocultar el texto ingresado.
- Tocá Ingresar. Si sos Administrador, Organizador o Árbitro vas al Panel; si sos Participante o Usuario público vas a tu Perfil.



5. Consultar torneos, calendario y posiciones

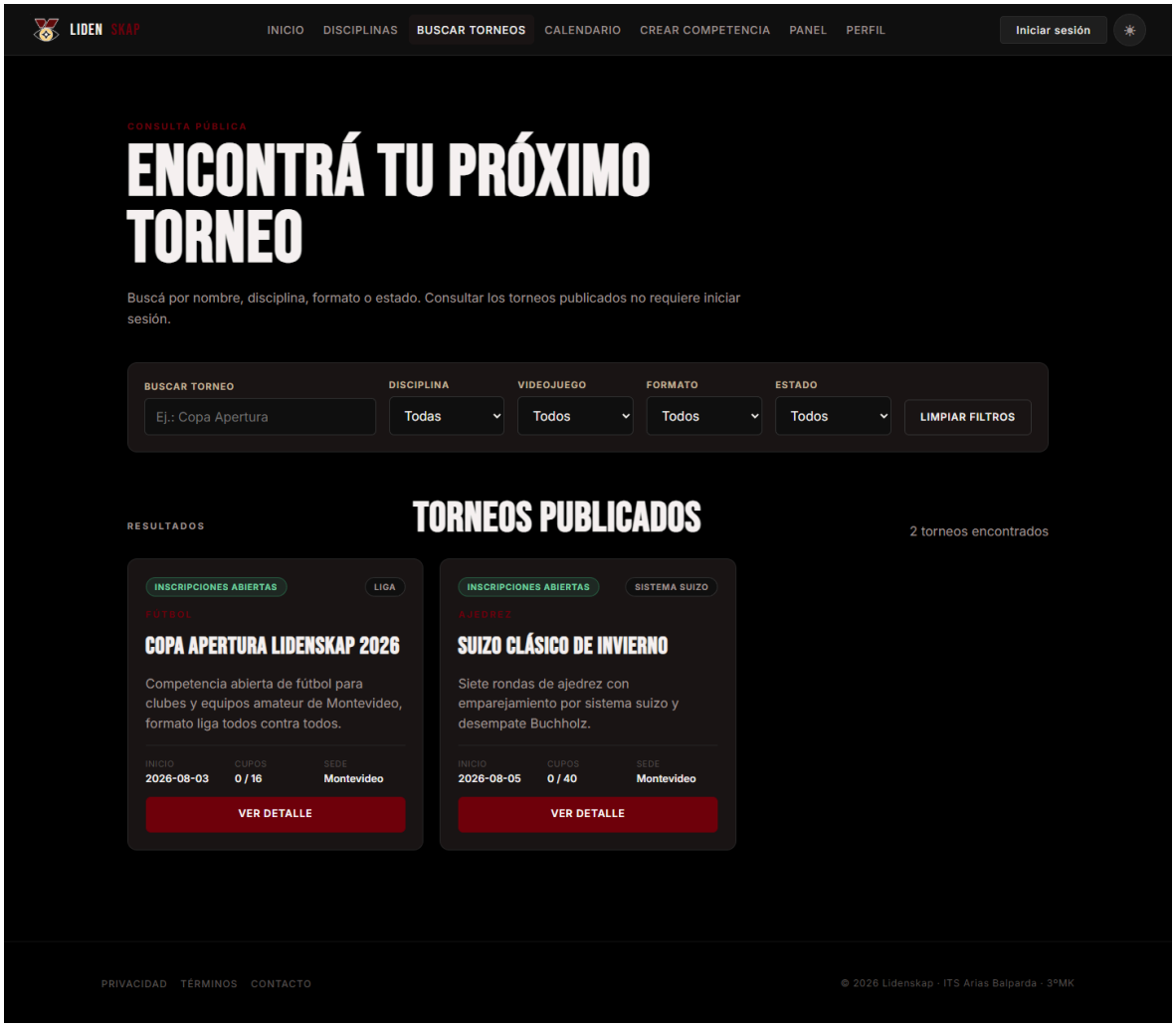
Acceso: Público, sin sesión

Listado público de todos los torneos publicados, con filtros por nombre, disciplina, videojuego, formato y estado. Esta captura muestra los dos torneos reales creados para

esta demostración (Copa Apertura Lidenskap 2026 y Suizo Clásico de Invierno), dados de alta a través del propio formulario de creación de competencias.

Buscar un torneo

1. Entrá a Buscar torneos.
2. Escribí parte del nombre o la sede, o filtrá por Disciplina, Videojuego, Formato y Estado. La lista se actualiza sola.
3. Limpiar filtros vuelve a mostrar todo.
4. Tocá Ver detalle en la tarjeta del torneo.

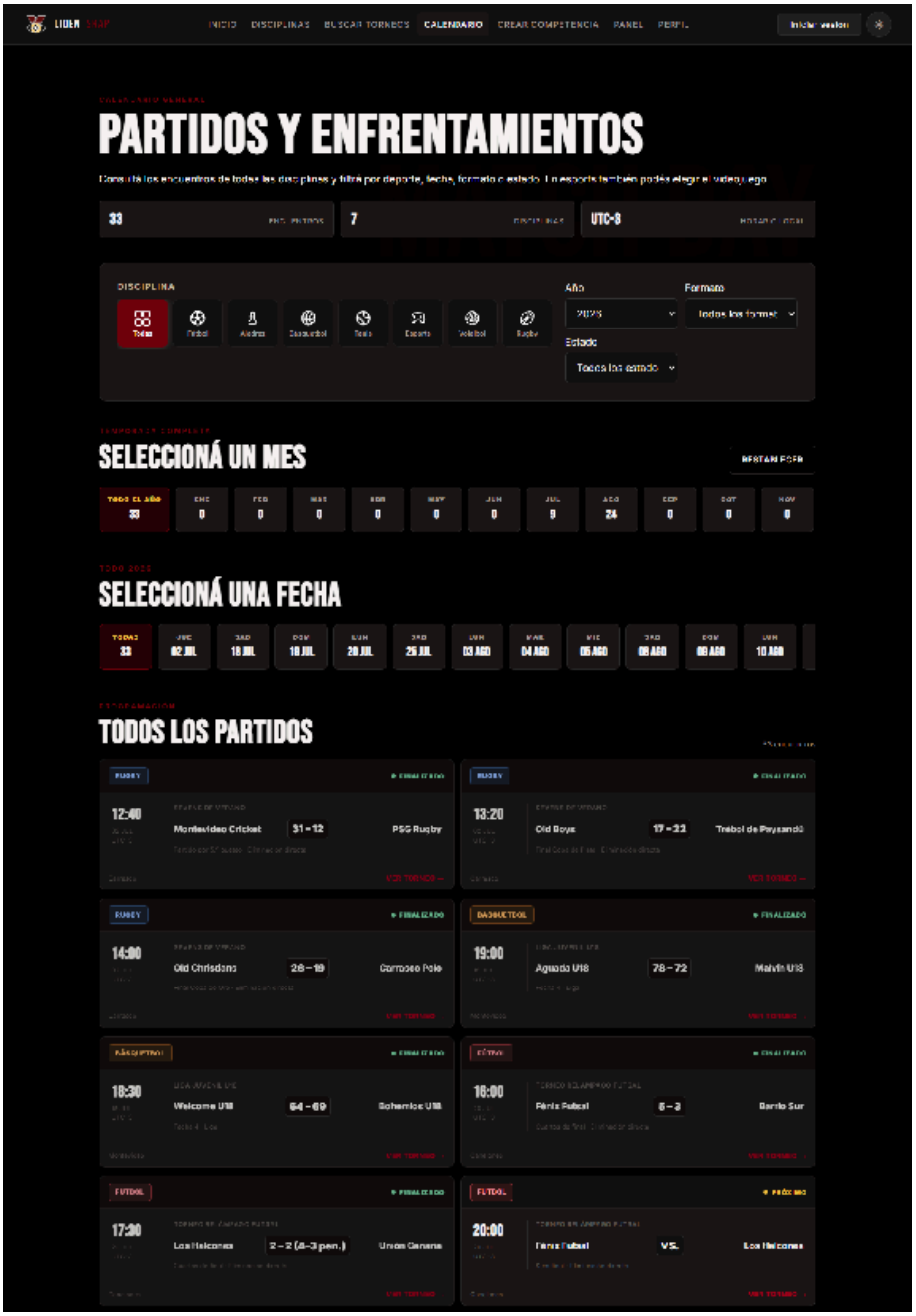


6. Ver el calendario.

Acceso: Público, sin sesión

Calendario general de encuentros de todas las disciplinas, con filtros por deporte, mes, fecha, formato y estado (próximo / finalizado).

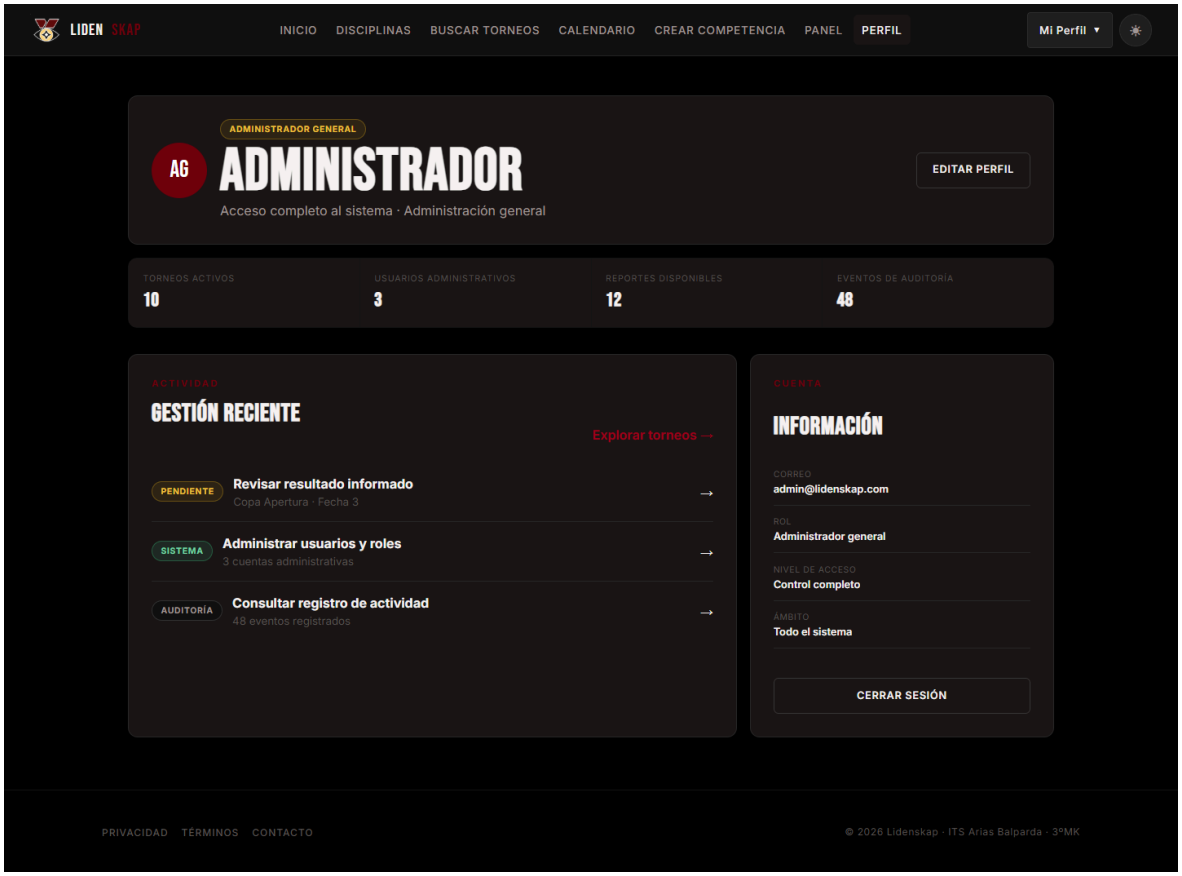
En Calendario elegí la disciplina con los íconos, el año, el mes y el día; también podés filtrar por formato y estado. Cada tarjeta muestra hora (UTC−3), rivales, resultado si ya se jugó y un enlace Ver torn



7. Mi perfil (Administrador)

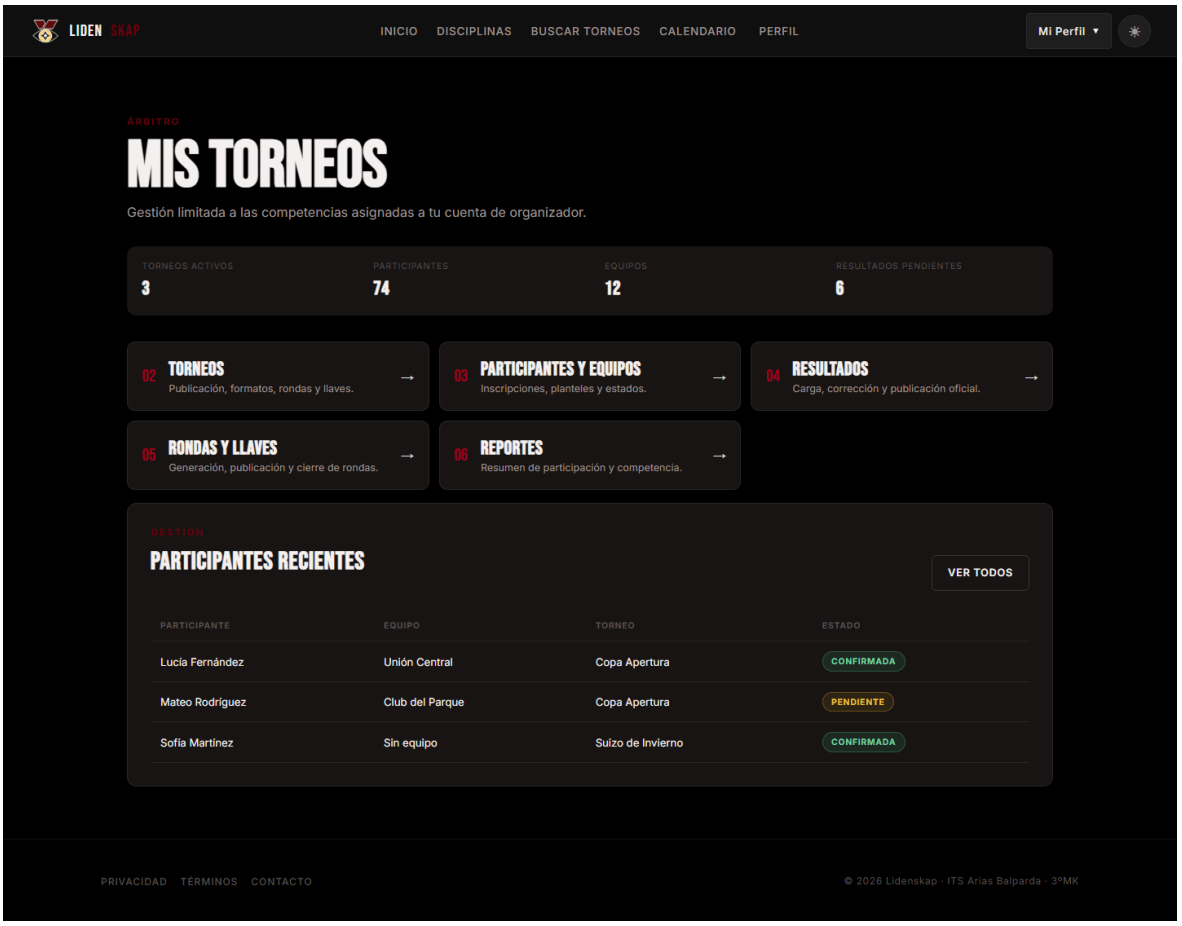
En Perfil ves datos de la cuenta propia y un resumen de actividad que cambia según el rol. El Administrador ve torneos activos, usuarios administrativos, reportes y eventos de auditoría; otros roles ven estadísticas propias de su actividad.

1. Tocá Editar perfil.
2. Cambiá nombre visible, teléfono o presentación.
3. Tocá Guardar cambios.



8. Gestionar un torneo (Organizador y Administrador)

Todo se hace desde el Panel. El Organizador ve solo los torneos que tiene asignados.

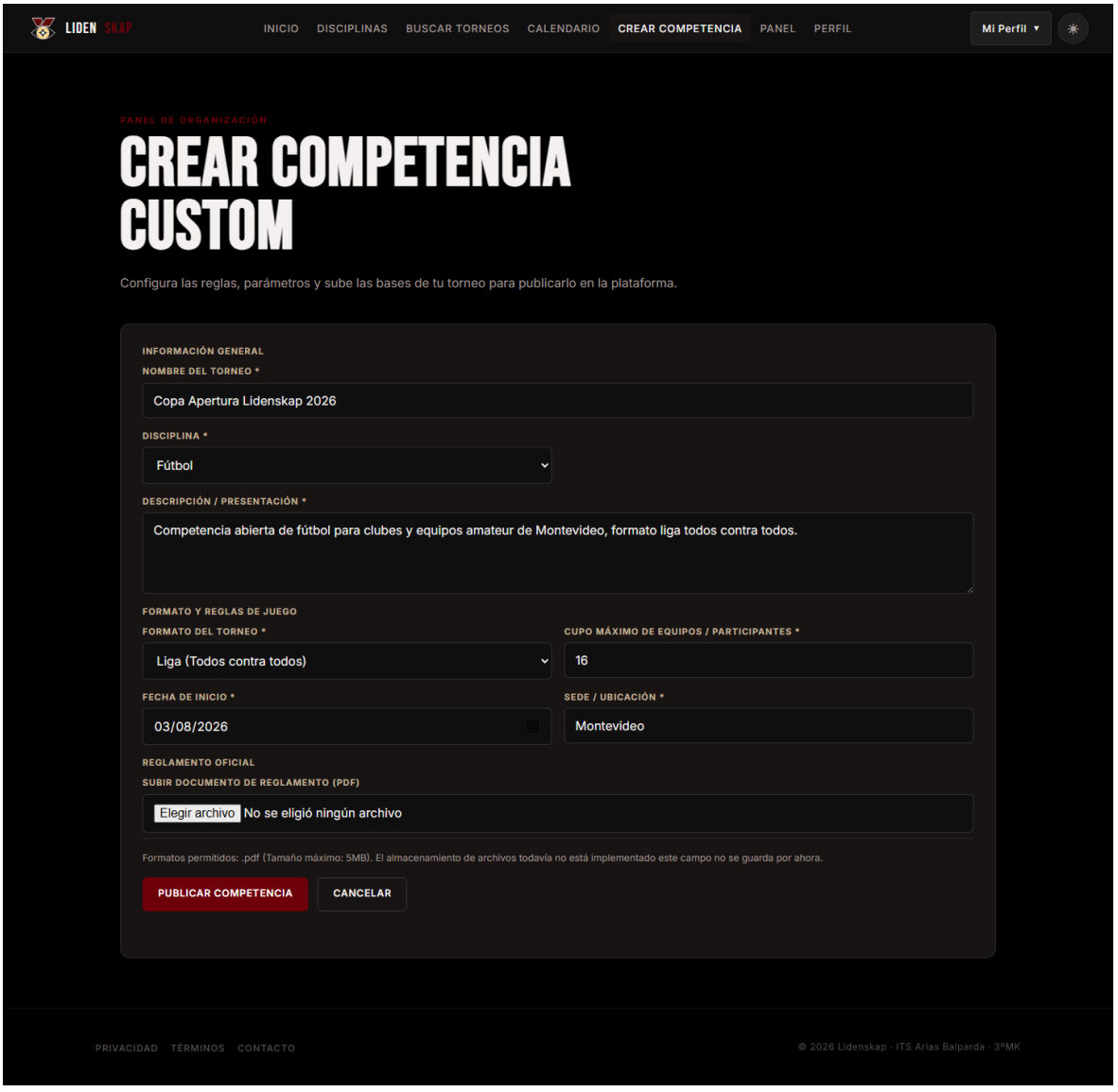


8. Crear competencia

Acceso: Solo Administrador

Formulario de alta de un torneo nuevo: disciplina, formato (Liga / Eliminación Directa / Sistema Suizo), cupo máximo, fecha de inicio, sede y reglamento. Esta captura muestra el formulario completo con los datos de "Copa Apertura Lidenskap 2026" cargados, justo antes de publicarlo.

1. Tocá + Nueva competencia en el Panel (o Crear competencia en la barra).
2. Completá los campos. Los marcados con * son obligatorios.
3. Tocá Publicar Competencia. El torneo aparece en Buscar torneos con estado Inscripciones abiertas.



9. Generar enfrentamientos (rondas y llaves)

1. Con las inscripciones cerradas, abrí Rondas y llaves.
2. Elegí el torneo en la lista. Arriba ves el formato, la ronda actual y su estado.

3. Tocá + Generar siguiente ronda. El sistema arma los cruces según el formato: todos contra todos en liga, llaves en eliminación directa o emparejamiento por puntaje en suizo. La ronda queda en Borrador.
4. Revisá los cruces y tocá Publicar ronda para que se vean en la consulta pública.
5. Cuando todos los resultados estén cargados, tocá Cerrar ronda. Desde ese momento los resultados quedan bloqueados y solo el Administrador puede reabrirla.

10. Cargar y corregir resultados

1. Abrí Resultados. Filtrá por Pendientes para ver lo que falta cargar.
2. Tocá Cargar en la fila del enfrentamiento.
3. Escribí el marcador (por ejemplo 2 – 1) y elegí el estado: Pendiente o Oficial.
4. Tocá Guardar cambios. Al quedar Oficial, la tabla de posiciones o la llave se actualizan.

Para corregir un resultado Oficial, el Organizador toca solicitar corrección y el sistema envía una solicitud de autorización al Administrador; el Administrador lo corrige directamente con el botón Corregir. Toda corrección queda en la auditoría.

11. Consultar posiciones y reportes

- Posiciones: en el detalle público del torneo (C.6). En liga, el desempate sigue este orden: puntos, diferencia de goles, enfrentamiento directo, goles a favor y sorteo.
- Reportes: en el Panel, Reportes muestra inscripciones, ocupación del cupo, partidos y resultados oficiales por torneo. Descargar CSV baja la tabla para abrirla en una planilla.

12. Publicar información

- El torneo: al tocar Publicar Competencia queda visible en Buscar torneos
- Los enfrentamientos : publicar ronda en Rondas y llaves
- Los resultados: marcarlos como Oficial. Si el Administrador activó Publicación automática, se publican al confirmarlos
- Las posiciones: se recalculan solas con cada resultado oficial

13. Cargar resultados como Árbitro

1. Iniciá sesión con tu cuenta de Árbitro; entrás al Panel.
2. Abrí Resultados: ves solo los encuentros que tenés asignados.
3. Cargá el marcador como en C.8.4. Podés actualizarlo hasta que el Organizador cierre la ronda.

El Árbitro no crea ni elimina torneos, rondas ni participantes.

BLOQUE F: Manual de administrador

Este manual es para el Administrador general (ROL-01) y para quien mantiene el servidor. La primera parte cubre la administración desde el Panel (usuarios, torneos, auditoría, configuración); la segunda, la instalación, los scripts, los respaldos, el monitoreo y la resolución de problemas.

1. Accesos del administrador

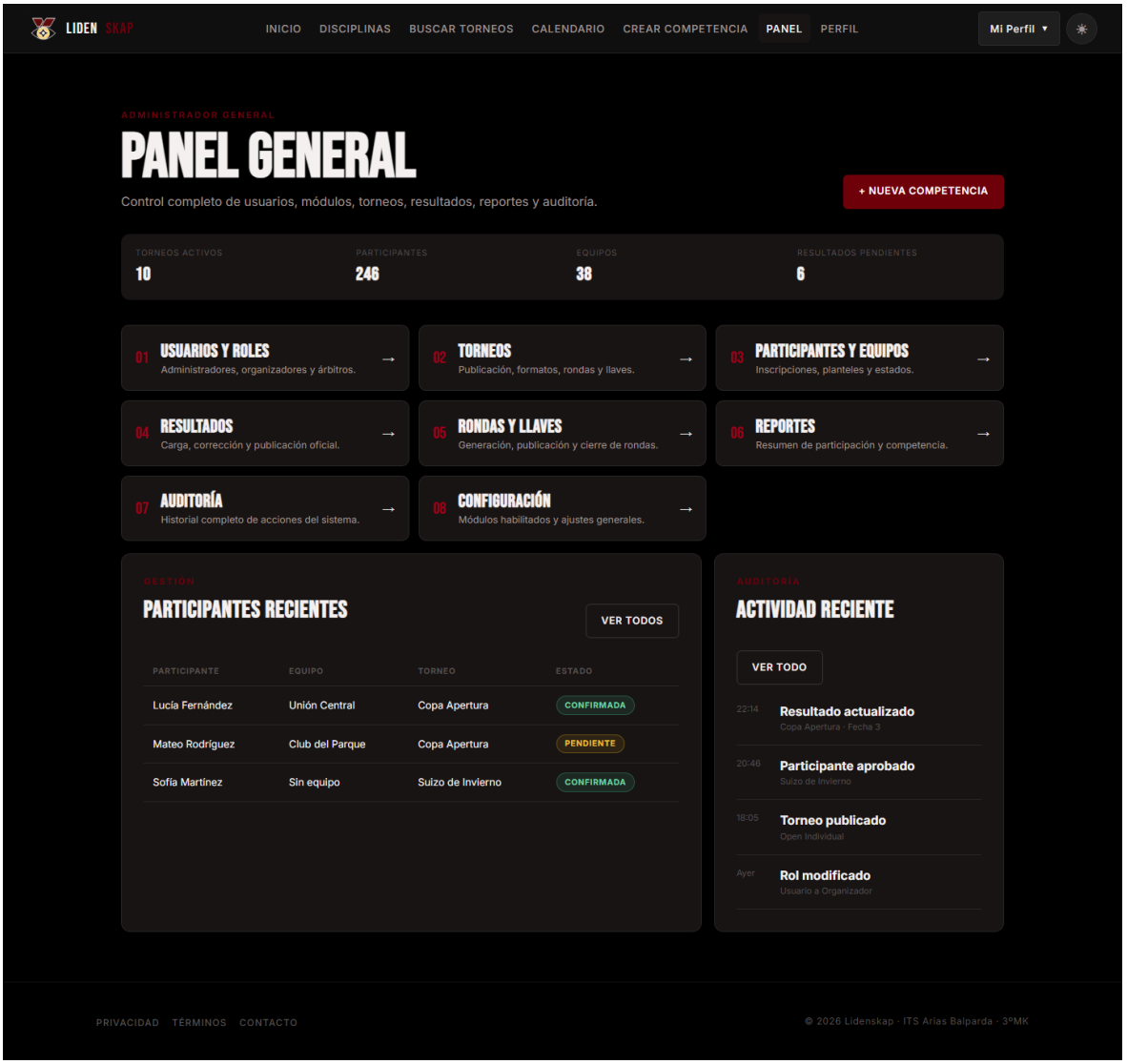
Nivel	Cuenta	Para qué	Cómo se obtiene
Aplicación	Usuario con rol ADMIN (inicial: admin@lidenskap.com)	Administrar desde el Panel	Viene en 03-seed-demo.sql; cambiar la contraseña antes de producción
Servidor	Usuario Linux del grupo sgdm_admins	Entrar por SSH (puerto 22) y usar sudo	sudo gestion_usuarios.sh crear-admin <usuario> "<Nombre>"
Servicio	svc_sgdm	Dueño de los archivos de la app; sin inicio de sesión	gestion_usuarios.sh provisionar
Base de datos	sgdm_admin	Mantenimiento y respaldos (todos los privilegios sobre sgdm)	02-users.sh
Base de datos	sgdm_app	La usa PHP: solo SELECT, INSERT, UPDATE, DELETE, sin cambiar la estructura	02-users.sh
Base de datos	sgdm_consulta	Solo lectura de las tablas públicas	02-users.sh
Base de datos	netdata_monitor	Solo metadatos para el monitoreo	monitoreo_sgdm.sh collectors-mysql

2. Panel general

Acceso: Administrador, Organizador o Árbitro

Vista general del panel administrativo: estadísticas del sistema y accesos directos a cada módulo (Usuarios y roles, Torneos, Participantes y equipos, Resultados, Rondas y llaves, Reportes, Auditoría, Configuración). Los módulos de Auditoría y Configuración son exclusivos del Administrador.

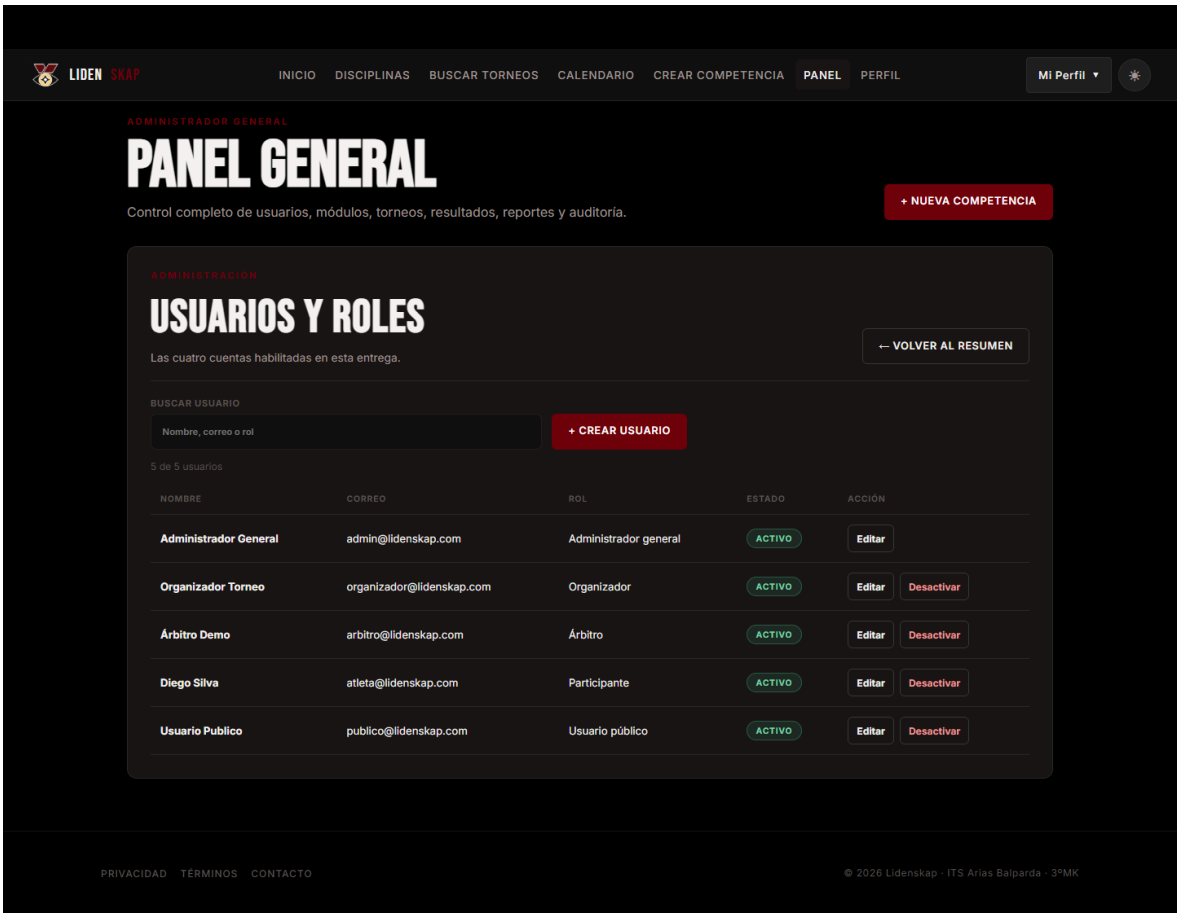
Al iniciar sesión como Administrador entrás al Panel general: arriba, los indicadores (torneos activos, participantes, equipos, resultados pendientes); abajo, los ocho módulos y la actividad reciente.



3. Usuarios y roles

Acceso: Solo Administrador

Alta, edición y baja de cuentas administrativas. Se ve la cuenta "Árbitro" (arbitro@lidenskap.com) junto a las demás cuentas de demostración, con su rol correctamente asignado. Desde acá el Administrador puede crear nuevas cuentas de Administrador, Organizador o Árbitro, Participante y Usuario público no se dan de alta manualmente, se obtienen por inscripción o autorregistro.



Crear un usuario administrativo

1. Panel -> Usuarios y roles -> Crear usuario.
2. Completá nombre, apellido, correo y contraseña inicial (mínimo 8 caracteres).
3. Elegí el rol: Administrador general, Organizador o Árbitro. Desde aquí no se crean Participantes ni Usuarios públicos: el público se registra solo y el Participante surge de una inscripción.
4. Tocá Guardar cambios y comunicá la contraseña por un canal privado.

Editar o cambiar de rol: editar en la fila permite cambiar nombre, apellido, correo y rol. Así se convierte a un Usuario público en Participante o a un Participante en Organizador.

Desactivar: hace una baja lógica, la cuenta queda inactiva, no puede iniciar sesión y su historial de torneos se conserva. No podés desactivar tu propia cuenta. Para reactivarla, mientras no exista el botón, se usa la base de datos:

UPDATE usuario SET estado = 'activo' WHERE email = 'persona@correo.com';

El buscador filtra por nombre, correo o rol.

4. Torneos y rondas

Crear: solo el Administrador; el procedimiento está en C.8.1.

- Eliminar: en el detalle del torneo, Eliminar torneo. Se borran también sus rondas, inscripciones, enfrentamientos, resultados y posiciones, y no se puede deshacer. Antes de eliminar, ejecutá un respaldo (sudo respaldo_sgdm.sh bd).
- Reabrir una ronda cerrada: solo el Administrador, desde Rondas y llaves. Queda registrado en la auditoría (RF-13).
- Corregir un resultado oficial: el Administrador corrige directamente; el Organizador debe pedir autorización (C.8.4).

5. Auditoría

Panel -> Auditoría muestra fecha y hora, usuario, acción, módulo y detalle de cada cambio. Se puede buscar por usuario, acción o módulo y Exportar registro a CSV. En la base de datos cada evento queda en auditoria_registro con usuario, acción, tabla afectada, fecha y hora e IP de origen.

BLOQUE G: Diagrama de Gantt (cronograma de la gestión del proyecto completo).

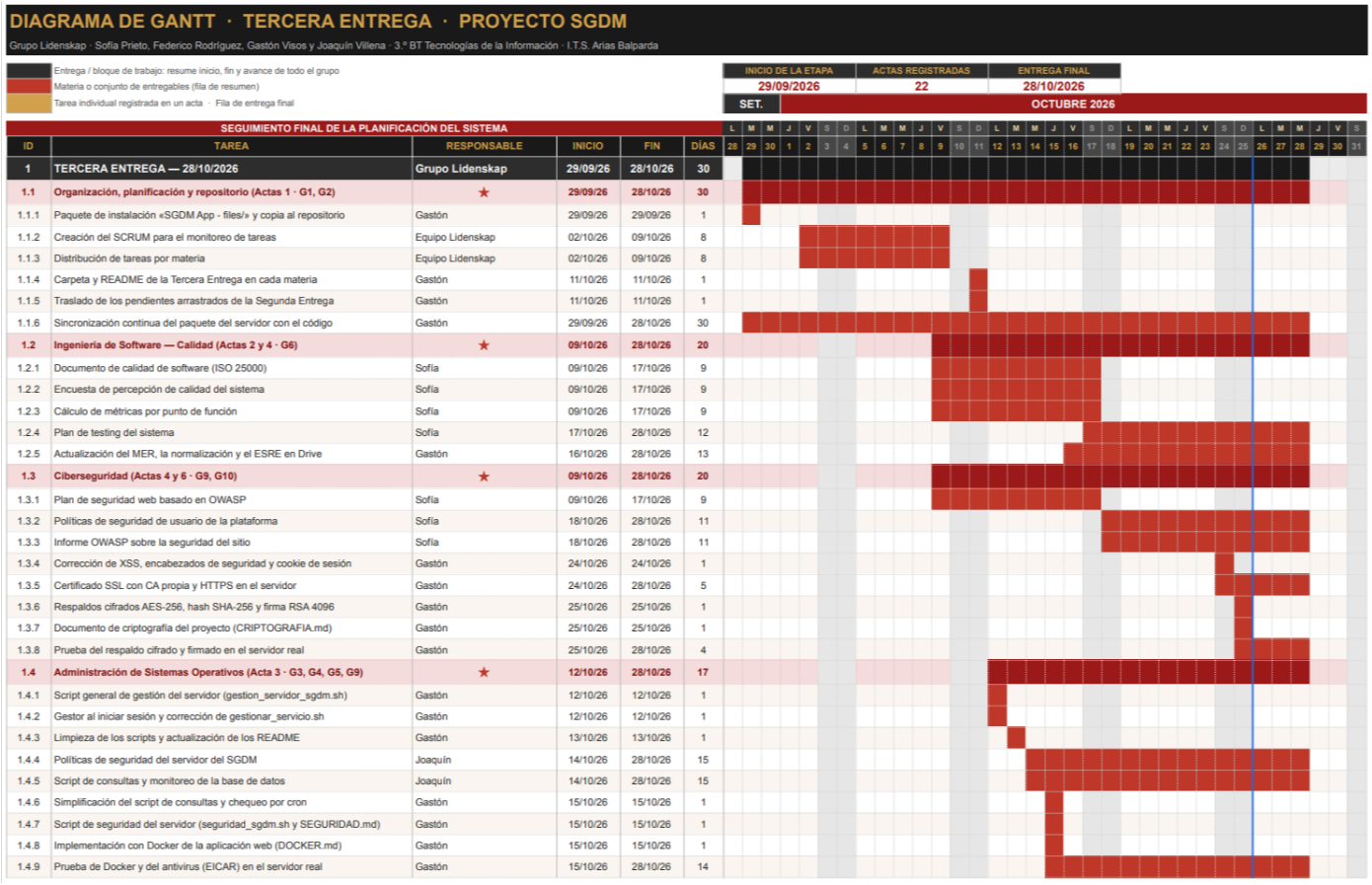


DIAGRAMA DE GANTT · TERCERA ENTREGA · PROYECTO SGDM

Grupo Lidenskap · Sofía Prieto, Federico Rodríguez, Gastón Visos y Joaquín Villena · 3.º BT Tecnologías de la Información · I.T.S. Arias Balparda

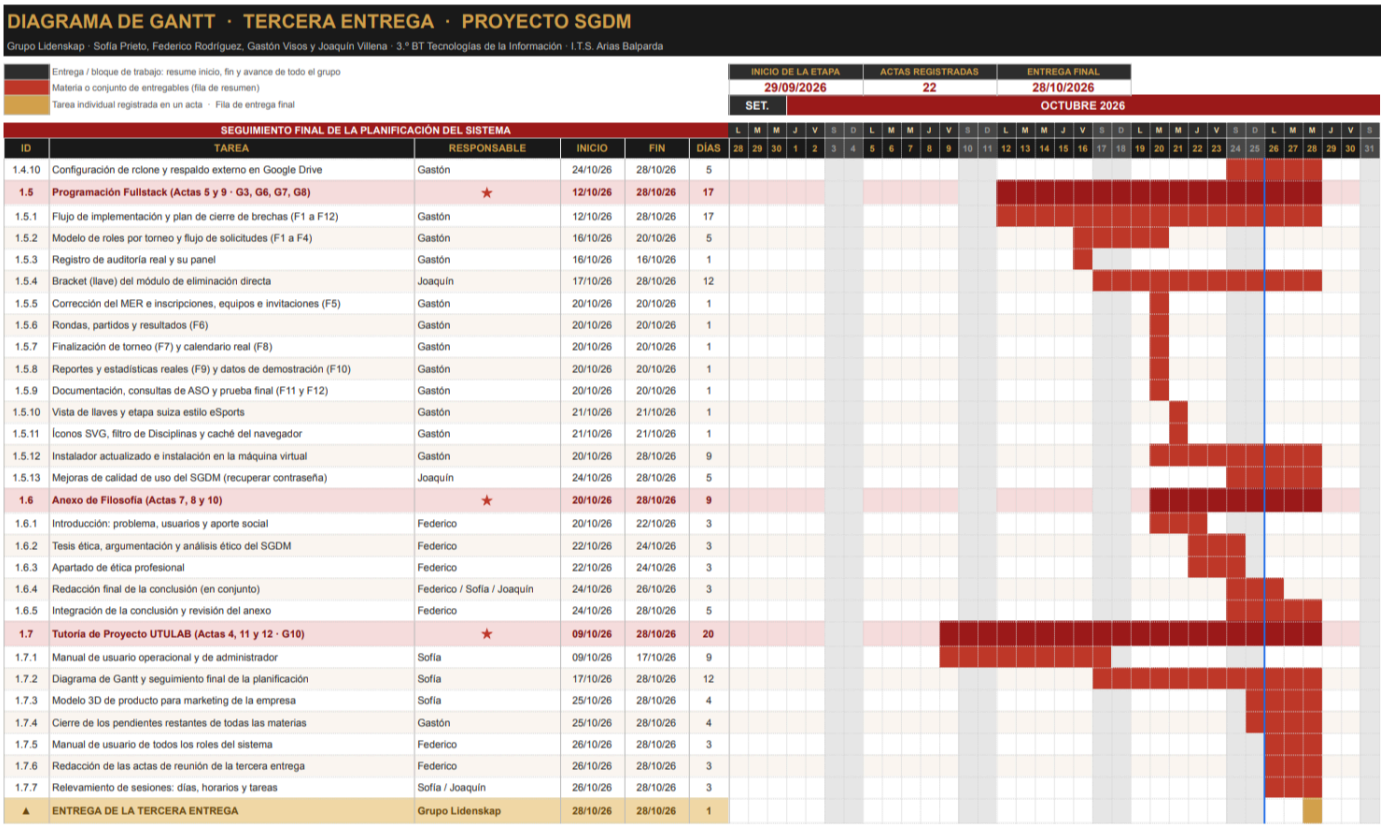
Entrega / bloque de trabajo: resume inicio, fin y avance de todo el grupo
Materia o conjunto de entregables (fila de resumen)
Tarea individual registrada en un acta · Fila de entrega final

INICIO DE LA ETAPA	ACTAS REGISTRADAS	ENTREGA FINAL
29/09/2026	22	28/10/2026

SET. | OCTUBRE 2026

SEGUIMIENTO FINAL DE LA PLANIFICACIÓN DEL SISTEMA

ID	TAREA	RESPONSABLE	INICIO	FIN	DÍAS
1	TERCERA ENTREGA — 28/10/2026	Grupo Lidenskap	29/09/26	28/10/26	30
1.1	**Organización, planificación y repositorio (Actas 1 · G1, G2)**	★	29/09/26	28/10/26	30
1.1.1	Paquete de instalación «SGDM App - files/» y copia al repositorio	Gastón	29/09/26	29/09/26	1
1.1.2	Creación del SCRUM para el monitoreo de tareas	Equipo Lidenskap	02/10/26	09/10/26	8
1.1.3	Distribución de tareas por materia	Equipo Lidenskap	02/10/26	09/10/26	8
1.1.4	Carpeta y README de la Tercera Entrega en cada materia	Gastón	11/10/26	11/10/26	1
1.1.5	Traslado de los pendientes arrastrados de la Segunda Entrega	Gastón	11/10/26	11/10/26	1
1.1.6	Sincronización continua del paquete del servidor con el código	Gastón	29/09/26	28/10/26	30
1.2	**Ingeniería de Software — Calidad (Actas 2 y 4 · G6)**	★	09/10/26	28/10/26	20
1.2.1	Documento de calidad de software (ISO 25000)	Sofía	09/10/26	17/10/26	9
1.2.2	Encuesta de percepción de calidad del sistema	Sofía	09/10/26	17/10/26	9
1.2.3	Cálculo de métricas por punto de función	Sofía	09/10/26	17/10/26	9
1.2.4	Plan de testing del sistema	Sofía	17/10/26	28/10/26	12
1.2.5	Actualización del MER, la normalización y el ESRE en Drive	Gastón	16/10/26	28/10/26	13
1.3	**Ciberseguridad (Actas 4 y 6 · G9, G10)**	★	09/10/26	28/10/26	20
1.3.1	Plan de seguridad web basado en OWASP	Sofía	09/10/26	17/10/26	9
1.3.2	Políticas de seguridad de usuario de la plataforma	Sofía	18/10/26	28/10/26	11
1.3.3	Informe OWASP sobre la seguridad del sitio	Sofía	18/10/26	28/10/26	11
1.3.4	Corrección de XSS, encabezados de seguridad y cookie de sesión	Gastón	24/10/26	24/10/26	1
1.3.5	Certificado SSL con CA propia y HTTPS en el servidor	Gastón	24/10/26	28/10/26	5
1.3.6	Respaldos cifrados AES-256, hash SHA-256 y firma RSA 4096	Gastón	25/10/26	25/10/26	1
1.3.7	Documento de criptografía del proyecto (CRIPTOGRAFIA.md)	Gastón	25/10/26	25/10/26	1
1.3.8	Prueba del respaldo cifrado y firmado en el servidor real	Gastón	25/10/26	28/10/26	4
1.4	**Administración de Sistemas Operativos (Acta 3 · G3, G4, G5, G9)**	★	12/10/26	28/10/26	17
1.4.1	Script general de gestión del servidor (gestion_servidor_sgdm.sh)	Gastón	12/10/26	12/10/26	1
1.4.2	Gestor al iniciar sesión y corrección de gestionar_servicio.sh	Gastón	12/10/26	12/10/26	1
1.4.3	Limpieza de los scripts y actualización de los README	Gastón	13/10/26	13/10/26	1
1.4.4	Políticas de seguridad del servidor del SGDM	Joaquín	14/10/26	28/10/26	15
1.4.5	Script de consultas y monitoreo de la base de datos	Joaquín	14/10/26	28/10/26	15
1.4.6	Simplificación del script de consultas y chequeo por cron	Gastón	15/10/26	15/10/26	1
1.4.7	Script de seguridad del servidor (seguridad_sgdm.sh y SEGURIDAD.md)	Gastón	15/10/26	15/10/26	1
1.4.8	Implementación con Docker de la aplicación web (DOCKER.md)	Gastón	15/10/26	15/10/26	1
1.4.9	Prueba de Docker y del antivirus (EICAR) en el servidor real	Gastón	15/10/26	28/10/26	14



ID	TAREA	RESPONSABLE	INICIO	FIN	DÍAS
1.4.10	Configuración de rclone y respaldo externo en Google Drive	Gastón	24/10/26	28/10/26	5
1.5	**Programación Fullstack (Actas 5 y 9 · G3, G6, G7, G8)**	★	**12/10/26**	**28/10/26**	**17**
1.5.1	Flujo de implementación y plan de cierre de brechas (F1 a F12)	Gastón	12/10/26	28/10/26	17
1.5.2	Modelo de roles por torneo y flujo de solicitudes (F1 a F4)	Gastón	16/10/26	20/10/26	5
1.5.3	Registro de auditoría real y su panel	Gastón	16/10/26	16/10/26	1
1.5.4	Bracket (llave) del módulo de eliminación directa	Joaquín	17/10/26	28/10/26	12
1.5.5	Corrección del MER e inscripciones, equipos e invitaciones (F5)	Gastón	20/10/26	20/10/26	1
1.5.6	Rondas, partidos y resultados (F6)	Gastón	20/10/26	20/10/26	1
1.5.7	Finalización de torneo (F7) y calendario real (F8)	Gastón	20/10/26	20/10/26	1
1.5.8	Reportes y estadísticas reales (F9) y datos de demostración (F10)	Gastón	20/10/26	20/10/26	1
1.5.9	Documentación, consultas de ASO y prueba final (F11 y F12)	Gastón	20/10/26	20/10/26	1
1.5.10	Vista de llaves y etapa suiza estilo eSports	Gastón	21/10/26	21/10/26	1
1.5.11	Íconos SVG, filtro de Disciplinas y caché del navegador	Gastón	21/10/26	21/10/26	1
1.5.12	Instalador actualizado e instalación en la máquina virtual	Gastón	20/10/26	28/10/26	9
1.5.13	Mejoras de calidad de uso del SGDM (recuperar contraseña)	Joaquín	24/10/26	28/10/26	5
1.6	**Anexo de Filosofía (Actas 7, 8 y 10)**	★	**20/10/26**	**28/10/26**	**9**
1.6.1	Introducción: problema, usuarios y aporte social	Federico	20/10/26	22/10/26	3
1.6.2	Tesis ética, argumentación y análisis ético del SGDM	Federico	22/10/26	24/10/26	3
1.6.3	Apartado de ética profesional	Federico	22/10/26	24/10/26	3
1.6.4	Redacción final de la conclusión (en conjunto)	Federico / Sofía / Joaquín	24/10/26	26/10/26	3
1.6.5	Integración de la conclusión y revisión del anexo	Federico	24/10/26	28/10/26	5
1.7	**Tutoría de Proyecto UTULAB (Actas 4, 11 y 12 · G10)**	★	**09/10/26**	**28/10/26**	**20**
1.7.1	Manual de usuario operacional y de administrador	Sofía	09/10/26	17/10/26	9
1.7.2	Diagrama de Gantt y seguimiento final de la planificación	Sofía	17/10/26	28/10/26	12
1.7.3	Modelo 3D de producto para marketing de la empresa	Sofía	25/10/26	28/10/26	4
1.7.4	Cierre de los pendientes restantes de todas las materias	Gastón	25/10/26	28/10/26	4
1.7.5	Manual de usuario de todos los roles del sistema	Federico	26/10/26	28/10/26	3
1.7.6	Redacción de las actas de reunión de la tercera entrega	Federico	26/10/26	28/10/26	3
1.7.7	Relevamiento de sesiones: días, horarios y tareas	Sofía / Joaquín	26/10/26	28/10/26	3
▲	**ENTREGA DE LA TERCERA ENTREGA**	**Grupo Lidenskap**	**28/10/26**	**28/10/26**	**1**